



Políticas e Análise de Risco na Segurança de Informação

Mestrado de Cibersegurança e Informática Forense

FitTech Solutions

Realizado por:

Fernando Silva, 2240255

Paulo Alves, 2240249

Rui Agostinho, 2240247

Sérgio Lopes, 2230050

Válter Pedrosa, 2240616

Docente:

Adail Oliveira

Leiria, janeiro de 2025

This page was intentionally left blank

Resumo

Este documento foi elaborado no âmbito da unidade curricular de **Políticas e Análise de Risco na Segurança da Informação**, do mestrado em **Cibersegurança e Informática Forense**. Focado no desenvolvimento e implementação de políticas de segurança da informação, o relatório baseia-se num caso de estudo fictício, a empresa **FitTech Solutions**, para explorar a importância de uma abordagem robusta à proteção de informações e dados sensíveis num cenário digital repleto de ameaças em constante evolução.

O relatório abrange de forma estruturada a análise do ambiente empresarial e da arquitetura dos sistemas de informação, identifica serviços e ativos críticos e examina a conformidade com legislações e padrões aplicáveis. Com base numa metodologia qualitativa de análise de risco, propõe políticas e medidas práticas que reforçam a resiliência da organização.

Além disso, o documento detalha controlos técnicos e estratégicos alinhados com o contexto corporativo, oferecendo uma visão abrangente e integrada para a proteção dos ativos e continuidade do negócio da **FitTech Solutions**.

Palavras-chave: Cibersegurança, Políticas, Segurança, Estratégia, Análise de Risco, Informação.

This page was intentionally left blank

Índice de Figuras

<i>Figura 1 Organograma organizacional da FitTech Solutions</i>	<i>6</i>
<i>Figura 2 - Estrutura da rede FitTech Solutions</i>	<i>13</i>
<i>Figura 3 -Organograma dos serviços prestados pela equipa de segurança.</i>	<i>21</i>
<i>Figura 4 - Plano estratégico de segurança da informação</i>	<i>22</i>
<i>Figura 5 - Matriz de Avaliação de Risco</i>	<i>28</i>

Índice de Tabelas

<i>Tabela 1 - Lista de competências e funções CISO, Técnicos TI e colaboradores</i>	20
<i>Tabela 2 - Cálculo da probabilidade e impacto da ocorrência de incidentes</i>	26
<i>Tabela 3 - Classificação de risco dos ativos</i>	31
<i>Tabela 4 - Propostas de controlo de segurança dos ativos</i>	33

Tabela de Acrónimos

B2B	Business to Business
B2C	Business to Consumer
BYOD	Bring Your Own Device
CEO	Chief Executive Officer
CISO	Chief Information Security Officer
CNCS	Centro Nacional de Cibersegurança
CNPD	Comissão Nacional de Proteção de Dados
CRM	Customer Relationship Management
CTO	Chief Technology Officer
DPO	Data Protection Officer
DMZ	Demilitarized zone
ERP	Enterprise Resource Planning
GSI	Gestão de Segurança da Informação
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
IRF	Instituto de Reabilitação e Fisioterapia
MDM	Mobile Device Management
NGFW	Next Generation Firewall
RGPD	Regulamento Geral de Proteção de Dados
SEO	Search Engine Optimization
SCM	Source Code Management
SGSI	Sistema de Gestão de Segurança da Informação
SIEM	Security Information and Event Management
SSL	Secure Sockets Layer
TI	Tecnologias de Informação
TLS	Transport Layer Security
UPS	Uninterruptible Power Supply
VPN	Virtual Private Network

Índice

Resumo	iii
Índice de Figuras	v
Índice de Tabelas	vi
Tabela de Acrónimos	vii
Índice	viii
1. Introdução	1
1.1. Motivação/Enquadramento	1
1.2. Objetivos previstos	1
1.3. Estrutura do documento	2
2. Caracterização do ambiente empresarial	3
2.1. Missão, visão e valores:	4
2.2. Produtos e Serviços:	4
2.3. Principais parceiros de negócio	4
2.4. Estrutura Organizacional	5
2.5. Modelo de negócio e clientes	7
2.6. Enquadramento Digital	7
3. Arquitetura do Sistema de Informação	9
3.1. Negócio e Unidades	9
3.2. Dados	9
3.3. Aplicações	10
3.4. Arquitetura Tecnológica	11
3.5. Localização dos ativos	14
4. Funções Críticas e ativos da organização	15
5. Conformidade com Legislação e Normas	17
5.1. Legislação Aplicável	17
5.2. Normas e Certificações	17
6. Responsável pela Segurança	18
6.1. Competências e Funções por entidade/colaborador	18
6.2. Serviços prestados pela Equipa de Segurança	20
6.3. Plano de segurança	22

6.4.	Localização do Serviço de Segurança	23
7.	Metodologia de Análise de Risco	23
7.1.	Identificação de Vulnerabilidades e Ameaças	23
7.2.	Cálculo da Probabilidade e do Impacto	26
7.3.	Avaliação da Criticidade dos Ativos	27
7.4.	Definição da Metodologia de Análise de Risco	29
7.5.	Realização da Análise de Risco	30
7.6.	Proposta de Controlo e Mitigação de Riscos	32
8.	Política de Segurança da Informação	34
8.1.	Perfil atual	34
8.2.	Perfil alvo	35
8.3.	Enumeração das Políticas de segurança	36
8.3.1.	Política de Formação em Segurança da Informação	36
8.3.2.	Gestão de Palavra-Passe	39
8.3.3.	Políticas de Acesso Lógico	41
8.3.4.	Políticas de Backup	44
8.3.5.	Política de Notificação de incidentes de Segurança da Informação	47
8.3.6.	Política de conformidade com o RGPD	49
8.3.7.	Política de Recuperação de Desastres	52
8.3.8.	ISO/IEC 27001:2022	54
8.4.	Classificação de ativos	54
8.4.1.	Critérios de Classificação	54
8.4.2.	Categorias de Classificação	54
8.4.3.	Diretrizes de proteção por categoria	55
8.4.4.	Aplicação da política de classificação	55
9.	Arquitetura de Segurança Perimétrica	55
9.1.	Análise de Riscos	56
9.2.	Controlos de Zonas Segurança	56
9.3.	Controlo de Acessos	57
9.3.1.	Alarme e Videovigilância	57
9.3.2.	Reconhecimento Facial	58
9.4.	Fluxos de Comunicação e Controlo	58
10.	Política de Uso Aceitável (PUA)	58
10.1.	Responsabilidades	58
10.2.	Utilização Aceitável	59
10.2.1.	BYOD	59

10.2.2.	Acesso à Internet	60
10.2.3.	Utilização de Correio Eletrónico	61
10.3.	Dispositivos Móveis	63
10.4.	Trabalho Remoto	64
10.5.	Cifra de Informação	64
10.6.	Gestão de Redes e Serviços	65
10.6.1.	Gestão de Contas e Acessos	66
10.6.2.	Gestão de Palavras-Chave	67
10.6.3.	Desenvolvimento de Aplicações	68
10.7.	Registo de Eventos ou Incidentes	69
<i>Referências Bibliográficas</i>		71
<i>Glossário</i>		72

This page was intetionally left blank

1. Introdução

O crescimento exponencial da digitalização nas últimas décadas tem transformado a forma como as organizações operam, gerem dados e se interligam com os seus clientes e parceiros. Este avanço trouxe inúmeras oportunidades, mas também elevou significativamente os riscos associados à segurança da informação. Para mitigar estas ameaças e garantir a confidencialidade, integridade e disponibilidade dos dados, torna-se essencial adotar práticas e políticas estruturadas, baseadas em normas reconhecidas como, por exemplo, a ISO/IEC 27001:2022. [1]

Este documento apresenta uma proposta para a implementação de um Sistema de Gestão de Segurança da Informação (SGSI) na **FitTech Solutions, Lda.** (de ora em diante referida como FitTech), uma empresa fictícia dedicada ao fabrico e comercialização de equipamentos de *fitness*, bem como ao desenvolvimento de soluções digitais para treino personalizado.

1.1. Motivação/Enquadramento

Este trabalho foi desenvolvido no âmbito da unidade curricular de Políticas e Análise de Risco na Segurança da Informação (PARSI), inserida no Mestrado em Cibersegurança e Informática Forense (MCIF), ministrado pelo Instituto Politécnico de Leiria. A escolha do tema e da abordagem prática foi motivada pelo interesse em aplicar os conhecimentos adquiridos durante o curso para resolver problemas reais, com ênfase na elaboração de um SGSI em conformidade com as normas ISO/IEC 27001:2022.

O desenvolvimento deste trabalho permitiu-nos consolidar competências na análise de riscos, na definição de políticas de segurança e na integração de tecnologias modernas para a proteção de dados. Esta simulação de um caso de estudo com a FitTech proporcionou-nos um ambiente controlado, mas suficientemente desafiador, para explorar as implicações práticas e teóricas da segurança da informação num contexto empresarial.

1.2. Objetivos previstos

O principal objetivo deste trabalho é desenvolver uma proposta abrangente para a implementação de um **SGSI** na empresa fictícia FitTech, de acordo com os requisitos e melhores práticas definidos pela norma ISO/IEC 27001:2022. Este sistema visa garantir a proteção da confidencialidade, integridade e disponibilidade das informações críticas, bem como a conformidade com regulamentações legais, como o **Regulamento Geral sobre a Proteção de Dados (RGPD)**.

De forma específica, os objetivos deste trabalho incluem:

- **Identificar e analisar o ambiente empresarial da FitTech**, compreendendo as suas atividades, parceiros de negócio, estrutura digital e os principais ativos de informação;
- **Avaliar riscos e vulnerabilidades associados à operação da empresa**, utilizando metodologias de análise de risco reconhecidas, como a ISO/IEC 27005:2022, para priorizar ameaças e propor medidas mitigadoras;
- **Definir políticas de segurança da informação que estabeleçam diretrizes claras para a gestão e proteção de dados**, abrangendo formação de colaboradores, controlo de acessos, uso aceitável de recursos e continuidade de negócios.
- **Desenhar uma arquitetura de segurança perimétrica** que assegure a proteção física e lógica dos ativos críticos da organização, com a implementação de controlos como videovigilância, *firewalls* e segmentação de redes.
- **Promover uma cultura de cibersegurança na organização**, através da sensibilização e formação contínua dos colaboradores sobre boas práticas e ameaças cibernéticas.
- **Garantir a aplicabilidade prática do SGSI**, criando um plano de implementação com etapas definidas, desde o levantamento de requisitos até a certificação ISO/IEC 27001:2022.

1.3. Estrutura do documento

Este documento encontra-se dividido em dez capítulos. Nesta secção do relatório encontra-se uma breve descrição do que pode encontrar em cada um deles.

O primeiro capítulo, **Introdução**, apresenta uma breve introdução sobre a Gestão de Segurança da Informação (GSI), um pequeno resumo do trabalho desenvolvido e os objetivos e problemas que motivaram a realização deste trabalho.

O segundo capítulo, **Caracterização do ambiente empresarial**, descreve o nome da empresa (FitTech Solutions, Lda.), localização (Lisboa, Porto, Faro), e os principais ramos de atividade (fabrico de equipamentos de *fitness*, comercialização em lojas físicas e *online*, e desenvolvimento de aplicações digitais). Neste capítulo é apresentada uma lista dos setores com os quais a empresa trabalha, como logística, fornecedores de matérias-primas, ginásios e distribuidores internacionais. É ainda efetuado um enquadramento digital onde é explicada a presença digital da empresa, incluindo loja *online*, CRM, aplicações móveis, e uso de infraestrutura *cloud*.

No terceiro capítulo, **Arquitetura do Sistema de Informação**, são definidas as unidades de negócio e principais processos, como encomendas, fabrico e suporte. Identificados os tipos de dados geridos (clientes, inventário, dados financeiros) e a sua classificação. É

mentionado o *software* utilizado (ERP, Shopify, AutoCAD) e os critérios de seleção baseados em padrões de segurança. Por fim, são detalhadas as tecnologias utilizadas, como sistemas operativos, redes VPN, armazenamento *cloud* híbrida, e medidas de segurança.

No quarto capítulo, **Funções ou Atividades Críticas**, são definidos os serviços e ativos críticos, como ERP, base de dados de clientes, e infraestrutura de redes, avaliados com base no impacto no negócio e na probabilidade de ameaças.

No quinto capítulo, **Conformidade com Legislação e Normas**, é mencionada a legislação Aplicável: Inclui o RGPD e o Decreto-Lei n.º 65/2021, de 30 de julho sobre cibersegurança. São ainda referidas normas e certificações onde se destaca a ISO/IEC 27001:2022 e seus objetivos de garantir a confidencialidade, integridade e disponibilidade da informação.

No sexto capítulo, **Responsável pela Segurança**, são definidas as responsabilidades do gestor de Tecnologias de informação (TI) e administradores de sistema, além de competências como formação em cibersegurança e gestão de risco. Inclui um cronograma para implementação de medidas de segurança ao longo de três anos.

No sétimo capítulo, **Metodologia de Análise de Risco**, são explicados os passos para identificar vulnerabilidades, calcular probabilidades e impactos, e implementar controlos baseados na ISO/IEC 27005:2022.

No oitavo capítulo, **Política de Segurança da Informação**, são definidos os objetivos para reduzir os riscos associados a dados críticos, classificando ativos por impacto e estabelecendo revisões trimestrais.

No nono capítulo, **Arquitetura de Segurança Perimétrica**, são detalhados os controlos de segurança, como segmentação de redes, regras de *firewall* e monitorização através de sistemas de prevenção de intrusões (IPS).

No décimo capítulo, **Política de Uso Aceitável (PUA)**, são definidas as diretrizes para uso dos recursos da organização, uso de e-mail profissional, navegação na *Internet*, utilização de dispositivos pessoais (BYOD), trabalho remoto (exigência de VPN e autenticação de dois fatores) e relato de incidentes de segurança.

2. Caracterização do ambiente empresarial

A FitTech Solutions, Lda, é uma sociedade por quotas pluripessoal, constituída por 5 sócios, com capital social de 20.000€. Sendo uma empresa de média dimensão com 120 empregados cuja sede se encontra em Lisboa, na Avenida da Liberdade, 280 2ºEsquerdo

1250-149. As sucursais situam-se no Porto, na Avenida dos Aliados, 99 3ºDireito 4000-066 e em Faro na Avenida da República, 231 8000-080. [2]

FitTech é uma empresa inovadora que se especializa no desenvolvimento e fabrico de artigos de ginásio de alta tecnologia, com foco em aplicações digitais que melhoram a experiência de *fitness*. Fundada em 2020, a empresa rapidamente se estabeleceu como líder de mercado em Portugal, conhecida pela sua integração perfeita de tecnologia e equipamentos desportivos.

2.1. Missão, visão e valores:

A **missão** da FitTech é empoderar os entusiastas do *fitness* com soluções tecnológicas inovadoras, transformando a forma como as pessoas interagem com o exercício físico e tornando o *fitness* mais acessível, eficaz e envolvente. A **visão** da empresa é tornar-se líder global em soluções de *fitness* integradas, expandindo a sua presença para mercados internacionais e continuando a inovar no cruzamento de tecnologia e saúde física. Os seus **valores** fundamentais incluem a inovação, com uma busca constante por melhorias e novas soluções; a qualidade, com um compromisso inabalável com a excelência em todos os produtos e serviços; o foco no cliente, priorizando as suas necessidades e bem-estar; e a sustentabilidade, promovendo práticas ambientalmente responsáveis em todos os aspetos da produção.

2.2. Produtos e Serviços:

A FitTech oferece uma ampla gama de produtos e serviços inovadores que transformam a experiência de *fitness*, combinando tecnologia de ponta com funcionalidade prática. Entre as suas principais soluções estão:

- **Equipamentos Inteligentes:** Máquinas de *cárdio* e musculação com sensores integrados para monitorizar o desempenho e adaptar automaticamente os exercícios às necessidades do utilizador.
- **Aplicações Móveis:** Aplicações para treinadores e utilizadores finais, oferece controlo de atividades, planos de treino personalizados e integração com equipamentos.
- **Plataforma de Gestão de Ginásio:** *Software* para a gestão de ginásios, incluindo gestão de clientes, agendamentos, e análises financeiras.
- **Realidade Virtual:** Programas de treino imersivos que utilizam realidade virtual para aumentar a motivação durante os exercícios.

2.3. Principais parceiros de negócio

A FitTech tem construído parcerias estratégicas com empresas e organizações de referência, que desempenham um papel essencial no fortalecimento da sua posição como

líder de mercado em soluções tecnológicas para *fitness*. Os principais parceiros de negócio incluem:

- **Fornecedores de Tecnologia e Componentes:** A empresa tem uma parceria com a Intel e STMicroelectronics, fabricantes de sensores e dispositivos eletrônicos de última geração, que garantem a qualidade e a precisão dos equipamentos inteligentes oferecidos pela FitTech.
- **Empresas de Software:** Parceira com a Microsoft e a OutSystems para o suporte e desenvolvimento de *software* colaborando na criação e atualização contínua das aplicações móveis e da plataforma de gestão de ginásios, assegurando integração perfeita e funcionalidades inovadoras.
- **Distribuidores e Revendedores:** A rede de distribuidores em Portugal e no estrangeiro facilita o acesso aos produtos da FitTech, permitindo à empresa expandir a sua presença em mercados estratégicos como por exemplo a Decathlon Portugal e a Spot Zone.
- **Ginásios e Centros de Fitness:** A parceria com o Fitness Hut e o Virgin Active Portugal permite testar, implementar e aperfeiçoar os produtos e serviços da empresa, garantindo que cumprem as reais necessidades dos utilizadores finais.
- **Organizações Académicas e de Pesquisa:** Cooperação com o Instituto Politécnico de Leiria e a Universidade de Coimbra para o desenvolvimento de novas tecnologias e estudos que ajudam a FitTech a manter-se na vanguarda da inovação.
- **Empresas de Realidade Virtual:** A cooperação com especialistas das empresas YDreams Global e Unilabs Portugal em realidade virtual permite à FitTech criar programas de treino imersivos e altamente motivadores, diferenciando-se da concorrência.

Essas parcerias são fundamentais para o sucesso da FitTech, permitindo à empresa continuar a oferecer produtos e serviços de alta qualidade, enquanto expande a sua atuação no mercado nacional e internacional.

2.4. Estrutura Organizacional

O enquadramento organizacional de uma empresa é essencial para garantir o alinhamento de funções, a eficiência operacional e a clareza na tomada de decisões. Este modelo organiza a empresa em diferentes departamentos, cada um com atribuições específicas e estruturado para contribuir com os objetivos estratégicos da organização. Abaixo, apresenta-se um panorama geral dos 8 departamentos que compõem a FitTech:

- **Direção Geral:** Inclui os principais líderes, o *Chief Executive Officer* (CEO), *Chief Technology Officer* (CTO) e *Chief Information Security Officer*

(CISO), responsáveis pela visão estratégica, inovação tecnológica e pelas tomadas de decisão da empresa.

- **Departamento de Investigação e Desenvolvimento:** Este departamento é formado por engenheiros de produto e *designers*, cuja missão é criar e melhorar produtos, garantindo a competitividade no mercado.
- **Departamento de Produção:** Composto por operadores e técnicos de controlo de qualidade, este setor assegura uma produção eficiente e um controlo rigoroso de padrões de qualidade.
- **Departamento de Vendas e Marketing:** Formado por especialistas em vendas e de *marketing*, focam-se na promoção e comercialização de produtos e no crescimento da carteira de clientes.
- **Departamento Contabilístico e Financeiro:** Inclui analistas financeiros, contabilistas e administrativos que gerem os recursos financeiros e asseguram a saúde económica da empresa.
- **Departamento de Recursos Humanos:** O departamento RH é responsável pela gestão do capital humano, desde recrutamento à formação dos colaboradores.
- **Departamento de Logística:** Área de logística, gestão de inventário e de *stocks* garante que a cadeia de abastecimento funcione eficientemente, desde o armazenamento até a distribuição.
- **Departamento de Tecnologia da Informação:** Área de desenvolvimento de *software* e de suporte TI, apoia a infraestrutura tecnológica e implementa as medidas de segurança de informação na empresa.



Figura 1 Organograma organizacional da FitTech Solutions

Fonte: Elaboração própria

Este modelo organizacional apresentado no organograma acima na Figura 1 promove a colaboração interdisciplinar e assegura que cada departamento esteja alinhado para alcançar metas comuns, tornando a empresa ágil e competitiva.

2.5. Modelo de negócio e clientes

A FitTech adota um modelo de negócio **Business to Business to Consumer (B2B2C)**, combinando a venda de produtos e serviços tanto para empresas como para consumidores finais. Este modelo permite à empresa atingir dois tipos principais de clientes: empresas que utilizam suas soluções tecnológicas nos seus negócios (**B2B**) e consumidores finais que procuram melhorar a sua experiência no *fitness* (**B2C**).

No âmbito **B2B**, a FitTech vende os seus equipamentos e serviços tecnológicos para os ginásios e centros de bem-estar, como a Virgin Active Portugal e o Fitness Hut, além de distribuidores como a Decathlon. Estas parcerias são essenciais para expandir a presença da empresa no mercado e alcançar um grande número de consumidores. Além disso, a FitTech pode colaborar com centros de reabilitação e bem-estar, oferecendo equipamentos para recuperação física, como máquinas que monitorizam a evolução do paciente, e soluções digitais integradas a programas de reabilitação como o Instituto de Reabilitação e Fisioterapia (IRF).

No modelo **B2C**, a FitTech também disponibiliza diretamente aos consumidores finais, especialmente os entusiastas do *fitness* que procuram melhorar o seu desempenho com a ajuda de tecnologias avançadas. Estes clientes podem aceder a equipamentos de ginásio inteligentes, aplicações de treino personalizados e programas de realidade virtual que tornam a experiência de *fitness* mais envolvente e eficaz.

2.6. Enquadramento Digital

A **presença digital** da FitTech é uma parte essencial da sua estratégia de crescimento e inovação. A empresa tem investido fortemente em várias plataformas digitais que não só melhoram a experiência do cliente, mas também otimizaram os seus processos internos. Uma das principais ferramentas é a **loja online**, que oferece uma experiência de compra intuitiva e segura. Através da loja, os clientes podem adquirir equipamentos de ginásio inteligentes, soluções de treino personalizadas e programas de realidade virtual. A plataforma é otimizada para que seja facilmente encontrada através dos motores de busca (*Search Engine Optimization* (SEO)), garantindo que os produtos sejam facilmente encontrados, e está integrada com um sistema de pagamento *online* permitindo transações seguras. Além disso, a loja *online* está interligada com o sistema **CRM**, permitindo à FitTech personalizar a comunicação com os clientes, acompanhar o histórico de compras e promover ofertas direcionadas, o que fortalece o relacionamento com o consumidor e aumenta a fidelização.

A empresa também oferece **aplicações móveis** para **Android** e **iOS**, tanto para os consumidores finais como para os ginásios e centros de *fitness*. Estas aplicações são fundamentais para proporcionar uma experiência personalizada de treino, permitindo aos utilizadores aceder a planos de treino, monitorizar o seu desempenho através dos equipamentos inteligentes e integrar as funcionalidades dos dispositivos móveis com os produtos FitTech. Para os ginásios, as aplicações oferecem ferramentas de gestão de clientes, agendamento de treinos e análise de performance, melhorando a gestão das instalações e a satisfação dos clientes. As aplicações são constantemente atualizadas para garantir que a empresa se mantenha na vanguarda da tecnologia e que a experiência do utilizador seja sempre aprimorada.

A **infraestrutura cloud** é outro componente crucial para a gestão eficiente da empresa. A utilização de plataformas *cloud* permite à empresa gerir de forma centralizada o **inventário** e as **vendas**, o que facilita o controlo em tempo real dos níveis de *stock* e das transações comerciais. A plataforma *cloud* garante uma gestão ágil do inventário, permitindo à empresa monitorizar e ajustar o *stock* conforme necessário, evitando ruturas e otimizando o reabastecimento. Esta solução também facilita a integração entre a loja *online* e os sistemas de vendas, assegurando que todas as transações, sejam *online* ou físicas, sejam centralizadas e monitorizadas eficientemente. A infraestrutura *cloud* oferece ainda **segurança de dados** de alta qualidade, com *backups* automáticos e cifra de informações sensíveis, garantindo que todos os dados da empresa e dos clientes estejam protegidos. A possibilidade de **acesso remoto** aos sistemas de gestão também permite que os colaboradores da FitTech, independentemente da sua localização, possam trabalhar de forma eficiente e colaborar em tempo real.

Além disso, a plataforma *cloud* possibilita a geração de **relatórios analíticos** detalhados sobre vendas, desempenho de produtos e comportamento do cliente, o que proporciona à empresa informações valiosas para tomar decisões estratégicas. Estes dados ajudam a FitTech a ajustar as suas campanhas de *marketing*, a melhorar seus produtos e a entender melhor as necessidades dos seus clientes.

Em conjunto, a loja *online*, as aplicações móveis, o *Customer Relationship Management* (CRM) e a infraestrutura *cloud* formam um ecossistema digital integrado que permite à FitTech operar de forma otimizada e escalável. Esses recursos não só melhoram a experiência do cliente, proporcionando-lhe uma interação personalizada e eficiente com a marca, mas também permitem à empresa gerir as suas operações de maneira mais eficaz, desde o controlo de inventário até a análise de vendas. Com essa forte presença digital, a FitTech posiciona-se como uma empresa inovadora e competitiva no mercado de *fitness* e tecnologia, pronta para expandir sua atuação, tanto em Portugal como internacionalmente.

3. Arquitetura do Sistema de Informação

A arquitetura do sistema de informação da FitTech foi projetada para suportar de forma eficiente as operações da empresa, permitindo uma experiência integrada tanto para os clientes finais quanto para os ginásios e centros de *fitness* parceiros. A arquitetura é composta por várias camadas interligadas, garantindo a gestão de dados, a automação de processos e a segurança, além de ser escalável para suportar o crescimento da empresa.

3.1. Negócio e Unidades

A FitTech opera no setor de equipamentos de ginásio de alta tecnologia, oferecendo soluções inovadoras que combinam tecnologia de ponta com produtos de *fitness*. A empresa está organizada de forma a responder tanto a clientes finais (B2C) como a ginásios e centros de *fitness* (B2B). A plataforma de e-commerce é a principal interface da FitTech. A loja *online* é onde os clientes podem explorar e comprar produtos como equipamentos de ginásio inteligentes e soluções de treino personalizadas. A plataforma está otimizada para oferecer uma experiência de compra intuitiva, acessível tanto em dispositivos móveis como em *desktops*. A loja *online* integra-se diretamente com o sistema de CRM, permitindo uma comunicação personalizada com os clientes e a promoção de ofertas específicas com base no histórico de compras. Além disso, a empresa oferece aplicações móveis para Android e iOS, que permitem aos utilizadores aceder a planos de treino, monitorizar o desempenho e interagir com os equipamentos inteligentes. Estas aplicações também se integram com o sistema *backend* para sincronização de dados. Para os ginásios e centros de *fitness* parceiros, existe um portal dedicado, que facilita a gestão de clientes, o agendamento de treinos e a análise de dados de performance.

A empresa está organizada em várias unidades, incluindo os departamentos de **Vendas e Marketing, Tecnologia da Informação, Recursos Humanos, Produção, etc.** todos interligados através de sistemas de gestão digital. Isso permite uma operação eficiente, garantindo que as necessidades dos clientes e dos parceiros sejam garantidas de forma eficaz.

3.2. Dados

A FitTech gere uma vasta gama de dados essenciais para o seu funcionamento, sendo estes armazenados e tratados de forma eficiente e segura. Os principais tipos de dados geridos pela empresa incluem **informação de clientes, inventário, dados financeiros e dados de subscrições digitais**.

A **informação de clientes** abrange dados pessoais, históricos de compras, preferências de produtos, interações com o suporte e comportamentos de utilização das aplicações

móveis e dos equipamentos inteligentes. Estes dados são fundamentais para personalizar a experiência do utilizador, otimizar a comunicação e promover campanhas de *marketing* direcionadas. Já o **inventário** é constantemente monitorizado para garantir que os níveis de *stock* estejam atualizados em tempo real, evitando ruturas ou excessos de produto. A empresa também gere **dados financeiros**, que incluem transações de vendas, faturação, contas a pagar e a receber, bem como a análise de receitas e despesas, o que permite uma gestão eficaz dos recursos financeiros. Além disso, os **dados de subscrições digitais** referem-se aos planos de subscrição de serviços como acesso a conteúdos exclusivos, planos de treino personalizados e programas de realidade virtual, permitindo à empresa oferecer um serviço contínuo e atualizado aos seus clientes.

Em termos de **classificação de dados**, a FitTech adota um modelo de segurança baseado na **ISO/IEC 27001:2022**, que garante a proteção e a confidencialidade da informação. Os dados são classificados em várias categorias, dependendo da sua sensibilidade. Os **dados públicos** são informações disponíveis ao público em geral, como materiais de *marketing* e informações sobre produtos. Os **dados internos** referem-se a informações operacionais que são acessíveis aos colaboradores da empresa, como processos internos e relatórios gerais. Os **dados confidenciais** são informações sensíveis que necessitam de proteção adicional, como os dados pessoais dos clientes e as informações financeiras. Finalmente, os **dados restritos** são informações altamente sensíveis, acessíveis apenas a um número muito restrito de pessoas dentro da organização, como estratégias empresariais e planos de desenvolvimento de novos produtos. A classificação rigorosa e a gestão adequada desses dados asseguram que a FitTech cumpra com as melhores práticas de segurança e com as normas de proteção de dados em vigor, garantindo a privacidade e a confiança dos seus clientes e parceiros.

3.3. Aplicações

A FitTech utiliza uma gama de aplicações e *software* que são fundamentais para a gestão das operações internas e para a experiência dos seus clientes. O desenvolvimento e integração de plataformas digitais desempenham um papel essencial no sucesso da empresa, permitindo-lhe oferecer soluções inovadoras e personalizadas.

Para o desenvolvimento das suas plataformas digitais, a FitTech recorre à plataforma OutSystems, uma ferramenta de *low-code* que facilita a criação de aplicações web e móveis de forma ágil e eficiente. Utilizando o OutSystems, a empresa consegue desenvolver soluções como a sua loja *online*, aplicações móveis para clientes finais e para ginásios, bem como o portal de gestão de ginásios. A plataforma permite à empresa personalizar rapidamente as funcionalidades de cada aplicação, adaptando-se às necessidades específicas dos utilizadores e dos parceiros. Além disso, o OutSystems garante a escalabilidade das soluções, o que é essencial para acompanhar o crescimento da FitTech e a expansão para novos mercados.

A empresa também implementa HubSpot CRM que se integra de forma fluida com todas as plataformas digitais. O CRM permite à FitTech gerir a relação com os seus clientes de maneira personalizada, acompanhando o histórico de compras, preferências de produtos, interações e comportamento dos utilizadores nas suas plataformas. A integração do CRM com a loja *online* e as aplicações móveis possibilita uma comunicação mais eficaz com os clientes, incluindo o envio de recomendações de produtos, promoções personalizadas e a gestão de suporte ao cliente. Esta integração assegura que todas as interações sejam registadas de forma centralizada, proporcionando à empresa uma visão completa do cliente e permitindo-lhe oferecer um serviço mais eficiente e orientado às suas necessidades.

Além disso, o CRM está também integrado com o sistema de *Enterprise Resource Planning* (ERP), SAP B1, e o *software* de gestão de inventário TradeGecko (atualmente conhecido como QuickBooks Commerce), o que permite uma gestão eficiente das vendas e do *stock* de produtos. O Shopify, utilizado para a plataforma de *e-commerce*, também se interliga com o CRM, garantindo que as transações e dados de clientes sejam atualizados em tempo real, oferecendo uma experiência de compra mais fluida e personalizada.

Para o desenvolvimento e *design* de novos produtos, a empresa recorre ao *software* de *design* 3D, AutoCAD. Este *software* é utilizado pelos engenheiros e *designers* da FitTech para a criação de protótipos dos equipamentos de ginásio inteligentes, garantindo que os produtos vão de encontro aos mais elevados padrões de qualidade e funcionalidade.

A seleção destas plataformas e soluções segue critérios rigorosos, com um foco especial na compatibilidade com padrões de segurança, como a ISO/IEC 27001:2022, garantindo que todas as informações, desde os dados financeiros até os dados pessoais dos clientes, sejam protegidas adequadamente. A integração e segurança dessas plataformas são essenciais para manter a confiança dos clientes e garantir o bom funcionamento das operações da empresa.

3.4. Arquitetura Tecnológica

A arquitetura tecnológica da FitTech é concebida para garantir eficiência operacional, escalabilidade, segurança e uma excelente experiência para os utilizadores finais. Esta arquitetura abrange várias camadas de tecnologia, incluindo os sistemas operativos, comunicação, armazenamento e segurança, alinhando-se com as necessidades da empresa e as melhores práticas do mercado.

Tecnologias - A FitTech adota um conjunto de tecnologias de ponta para apoiar as suas operações e o desenvolvimento de soluções inovadoras. A empresa utiliza plataformas como OutSystems para o desenvolvimento de aplicações, o que permite criar sistemas personalizados de forma rápida e eficiente. Para o *e-commerce*, é utilizada a plataforma Shopify, enquanto o HubSpot CRM e o QuickBooks Commerce (para gestão de

inventário) são integrados, proporcionando uma gestão centralizada de dados de clientes e *stock*. No desenvolvimento de produtos, a empresa recorre ao AutoCAD para design 3D e prototipagem.

Além disso, a FitTech aposta em *cloud computing* para suportar redundância na sua infraestrutura, utilizando soluções como Microsoft Azure, garantindo flexibilidade, escalabilidade e disponibilidade das suas plataformas.

Sistemas Operativos - Os sistemas operativos utilizados pela FitTech são escolhidos para garantir a compatibilidade com as aplicações e as plataformas adotadas pela empresa. Para os servidores, a empresa utiliza Linux CentOS, devido à sua estabilidade, segurança e flexibilidade, especialmente para a hospedagem de serviços em *cloud*. Para os escritórios e operações diárias, os colaboradores utilizam Windows 10/11, Android OS e macOS, conforme as preferências e necessidades de cada departamento. As aplicações móveis desenvolvidas para os utilizadores finais são compatíveis com Android e iOS, proporcionando uma experiência de utilização fluida e otimizada.

Comunicação - A comunicação interna e externa é um dos pilares do bom funcionamento da FitTech. Para a comunicação interna, a empresa utiliza ferramentas como Microsoft Teams para *chat*, videoconferências e colaboração em tempo real, e Slack para mensagens rápidas e organização de equipas de trabalho. A comunicação externa com os clientes e parceiros é feita através de e-mail usando a plataforma Microsoft Outlook, *chats* ao vivo nas plataformas de *e-commerce* e suporte ao cliente, além da presença em redes sociais para promoção e interação com a comunidade.

A FitTech implementa VPN para garantir o acesso remoto seguro aos sistemas internos, permitindo que os colaboradores trabalhem de forma eficiente e protegida, independentemente da sua localização. Para a comunicação interna e o acesso à rede, a empresa adota redes Wi-Fi segregadas, garantindo que as redes de tráfego corporativo e público sejam separadas, aumentando a segurança e a proteção contra acessos não autorizados. Para maior proteção das plataformas que se encontram acessíveis a partir da internet é utilizada uma Web Application Firewall (WAF). A Figura 2 demonstra a arquitetura de rede da empresa.

A autenticação multifator (MFA) é implementada para o acesso aos sistemas críticos, como o ERP, CRM e plataformas de e-commerce. A empresa adota o princípio do mínimo privilégio na gestão de acessos, garantindo que os colaboradores tenham acesso apenas aos dados e sistemas necessários para as suas funções. A monitorização contínua da segurança é feita com o auxílio de *software* de gestão de eventos e informações de segurança (SIEM), que permitem identificar e responder rapidamente a incidentes de segurança.

3.5. Localização dos ativos

Na arquitetura tecnológica da FitTech, a localização dos ativos é cuidadosamente definida com base em critérios legais, requisitos de segurança e a natureza dos dados e sistemas geridos. Esta abordagem garante conformidade regulatória, eficiência operacional e proteção robusta contra ameaças.

Crítérios Legais

A FitTech opera em conformidade com o RGPD, que rege o tratamento de dados pessoais na União Europeia. Para assegurar conformidade são adotadas as seguintes políticas:

- Os **dados de clientes** (informações pessoais, preferências de consumo, históricos de compras) são armazenados exclusivamente na Microsoft Azure na região da Europa, garantindo que os dados estão protegidos por legislação europeia.
- Os **dados das vendas**, como relatórios financeiros e informações de faturação, são tratados de forma segura, atendendo a requisitos fiscais e legais de retenção de dados estabelecidos pelas autoridades tributárias de Portugal.

Localização e Gestão dos Ativos

Os ativos da empresa são divididos entre a *cloud* e a infraestrutura *on-premises*, dependendo da criticidade da informação e das necessidades operacionais:

Ativos na *Cloud*

- **Dados de clientes:** Incluem informações pessoais, histórico de compras e dados de subscrições digitais, utilizados pelo CRM (HubSpot) e pela plataforma de e-commerce (Shopify).
- **Dados de vendas:** Abrangem informações transacionais, relatórios financeiros e métricas de desempenho, armazenados na Microsoft Azure.
- **Aplicações desenvolvidas:** Plataforma de gestão de ginásios, aplicações moveis para treinos e aplicações de realidade virtual.

- **Backup de dados não críticos:** Para garantir a continuidade de negócios em caso de falhas locais.

Ativos On-Premises

- **Informática de produção:** Inclui sistemas que controlam as máquinas e equipamentos inteligentes, como sensores e dispositivos IoT utilizados no fabrico de produtos.
- **Dados industriais e operacionais:** Referem-se a informações em tempo real recolhidas dos processos de produção, armazenadas em servidores locais para garantir baixa latência e alta disponibilidade.
- **Sistemas de design 3D:** Software como AutoCAD, utilizado para criar e modificar protótipos de produtos.
- **Equipamentos de rede e segurança:** *Firewalls*, servidores de autenticação, VPN e infraestrutura de TI que suporta operações locais.

Critérios de Segurança

- **Cloud:** Os dados armazenados na *cloud* são protegidos por encriptação avançada (em trânsito e em repouso), autenticação multifator (MFA) e políticas rigorosas de gestão de acesso. Os *backups* são realizados regularmente e seguem um plano de recuperação de desastres.
- **On-Premises:** Os servidores e equipamentos locais estão em ambientes fisicamente seguros, com controlo de acesso restrito, monitorização por vídeo e sistemas de deteção de intrusão.

Esta abordagem híbrida permite à FitTech maximizar a eficiência e a segurança dos seus ativos, enquanto cumpre rigorosamente as obrigações legais e garante a continuidade operacional.

4. Funções Críticas e ativos da organização

A presente secção aborda a identificação dos ativos da organização e as funções críticas dentro da mesma, sendo uma etapa importante para a enumeração de possíveis vulnerabilidades e para a elaboração de uma política de segurança.

De seguida são enumerados os serviços e ativos críticos identificados para a empresa.

Serviços Críticos:

- Gestão de produção e desenvolvimento de produtos
- Gestão de Financeira e *E-commerce*

- Sistema de Pagamento
- Gestão de relacionamento com os clientes
- Distribuição
- Manutenção da Infraestrutura TI

Ativos Críticos:

- Workstations
- Plataformas Digitais
 - **Shopify:** Plataforma de *e-commerce* para a venda de produtos e gestão de transações.
 - **HubSpot CRM:** Sistema para gestão de relacionamento com clientes.
 - **SAP Business One (ERP):** Ferramenta para integração e gestão de operações financeiras, inventário e recursos humanos.
 - **TradeGecko (QuickBooks Commerce):** *Software* para gestão de inventário e logística.
 - **AutoCAD:** *Software* de *design* 3D para desenvolvimento de produtos.
 - **OutSystems:** Plataforma para desenvolvimento e manutenção de aplicações móveis e web.
- Base de Dados
- Equipamentos de produção
 - Sensores IoT e dispositivos inteligentes utilizados na produção.
 - Máquinas controladas por *software* para fabrico e testes de produtos.
- Infraestruturas de redes e servidores
- Sistemas de segurança e monitorização
 - *Firewalls* e sistemas de deteção de intrusão (IDS).
 - Sistemas de gestão de eventos e informações de segurança (SIEM) para monitorização contínua.
 - Soluções de criptografia para dados em trânsito e em repouso.
- Lojas Físicas
- Armazém
- Colaboradores
- Dados:
 - **Clientes:** Informações pessoais, histórico de compras, preferências e subscrições.
 - **Inventário:** Níveis de *stock*, movimentação e previsão de necessidades.
 - **Financeiros:** Transações, faturação, contas a pagar e a receber.
 - **Industriais:** Informações em tempo real recolhidas durante os processos de produção.

5. Conformidade com Legislação e Normas

A conformidade com leis e regulamentos é essencial para a FitTech garantindo operações seguras, éticas e em conformidade com requisitos legais. A presente secção apresenta a legislação aplicável á empresa e as certificações relevantes.

5.1. Legislação Aplicável

A legislação da União Europeia estabelece diversas diretrizes e normas essenciais para vários setores. A seguinte legislação é aplicável à empresa:

- Regulamento Geral sobre a Proteção de Dados (RGPD):
 - Exige a proteção de dados pessoais de clientes e colaboradores;
 - Obriga a empresa a implementar diversas medidas para garantir a privacidade e a segurança de dados processados, incluindo cifra de dados e acesso restrito;
 - Podem ser aplicadas sanções à empresa em caso de não conformidade.
- Decreto-Lei n.º 65/2021 (Lei da Cibersegurança):
 - Estabelece os requisitos para a segurança de redes e sistemas de informação essenciais;
 - Inclui a notificação obrigatória de incidentes de segurança que possam comprometer a continuidade do negócio ou os direitos dos clientes.
- Código do Trabalho e Normas Laborais:
 - Regula a implementação de políticas de trabalho remoto e uso de dispositivos pessoais (BYOD), garantindo os direitos dos colaboradores.
- Diretivas sobre Comércio Eletrónico e Serviços Digitais:
 - Aplicáveis à operação da loja *online* da empresa, garantindo práticas seguras e transparentes em transações digitais.

5.2. Normas e Certificações

A FitTech está comprometida em aplicar as seguintes normas:

- ISO/IEC 27001:2022 - Gestão de Segurança da Informação:
 - Esta norma define os requisitos para implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI).

- A FitTech utiliza esta norma como base para proteger a confidencialidade, integridade e disponibilidade de informações críticas.
- ISO/IEC 27005:2022 - Gestão de Riscos em Segurança da Informação:
 - Estabelece uma abordagem estruturada para identificar, avaliar e mitigar riscos.
 - Apoia na priorização de ameaças e na implementação de controles eficazes.
- ISO/IEC 27701:2019 - Gestão de Privacidade da Informação:
 - Extensão da ISO/IEC27001:2022, focada em privacidade e proteção de dados pessoais, alinhada aos requisitos do RGPD.
- Certificação PCI DSS (Payment Card Industry Data Security Standard):
 - Obrigatória para a FitTech devido aos pagamentos digitais, garantindo a proteção dos dados de cartões de crédito.

6. Responsável pela Segurança

O CISO é o responsável pela segurança da empresa e desempenha um papel fundamental na proteção dos ativos físicos, humanos e digitais da organização. Trabalhando de forma transversal com os diversos departamentos, o CISO assegura o alinhamento das práticas de segurança aos objetivos estratégicos da empresa.

O CISO é também o contato direto com as empresas de consultoria externa, no âmbito da implementação da ISO/IEC 27001:2022 e, se necessário, aquando da gestão de incidentes de segurança após gestão interna de primeiro nível.

6.1. Competências e Funções por entidade/colaborador

A segurança da empresa é coordenada estrategicamente pelo CISO, que desempenha o papel de responsável tático, enquanto o Departamento de TI assume as competências operacionais necessárias para implementar e manter medidas de segurança eficazes, tais como a manutenção dos sistemas de monitorização e a implementação de políticas de controlo de acesso.

O CISO, reportando diretamente ao CEO, supervisiona o desenvolvimento e a execução de políticas de cibersegurança, promovendo formações regulares para os colaboradores e gerindo riscos relacionados à segurança da informação. Além disso, toma decisões no âmbito da Política de Utilização Aceitável, assegurando o uso ético e seguro dos recursos tecnológicos da organização.

Os colaboradores devem possuir competências técnicas em cibersegurança, gestão de riscos e conformidade com normativas, além de competências pessoais como comunicação eficaz e tomada de decisão sob pressão. A formação contínua será promovida para garantir que estas habilidades estejam sempre alinhadas às exigências do mercado

Apresentamos na Tabela 1 um organograma de competências e funções para o CISO, Técnico de TI e Colaborador Comum.

CARGO	COMPETÊNCIAS	FUNÇÕES
CISO	• Conhecimento aprofundado em cibersegurança e gestão de riscos. • Habilidades de liderança e gestão de equipas. • Capacidade de comunicação eficaz para interagir com diferentes níveis hierárquicos. • Conhecimento das regulamentações e normas de segurança, como ISO 27001. • Pensamento estratégico e habilidades de tomada de decisão.	• Desenvolver e implementar políticas de segurança da informação. • Supervisionar a conformidade com regulamentações de segurança. • Gerir incidentes de segurança e coordenar respostas a ameaças. • Conduzir avaliações de risco e auditorias de segurança. • Reportar ao CEO sobre o estado da segurança da informação na organização.
Técnico TI	• Conhecimento técnico em sistemas operacionais, redes e protocolos de segurança. • Habilidades analíticas para identificar e resolver problemas de segurança. • Capacidade de trabalhar sob pressão durante incidentes de segurança. • Conhecimento das melhores práticas de segurança e ferramentas de monitorização. • Comunicação eficaz para explicar questões técnicas a não especialistas.	• Implementar e gerir sistemas de segurança, como firewalls e IDS/IPS. • Monitorizar redes e sistemas para identificar vulnerabilidades e ameaças. • Realizar atualizações e patches de segurança regularmente. • Fornecer suporte técnico relacionado à segurança para outros departamentos. • Participar na resposta a incidentes de segurança e na recuperação de desastres.

CARGO	COMPETÊNCIAS	FUNÇÕES
Colaborador	• Consciência sobre a importância da segurança da informação. • Habilidade para reconhecer potenciais ameaças, como phishing e malware. • Disciplina em seguir procedimentos e políticas de segurança. • Capacidade de comunicação para relatar problemas de segurança. • Disposição para participar de formações e ser pró-ativo na busca de mais conhecimento sobre segurança de informação.	• Seguir as políticas e procedimentos de segurança estabelecidos pela organização. • Participar nas formações de segurança da informação. • Relatar atividades suspeitas ou incidentes de segurança ao responsável departamento TI. • Proteger informações sensíveis, utilizando senhas fortes e práticas seguras. • Evitar comportamentos que possam comprometer a segurança, como o uso de dispositivos não autorizados.

Tabela 1 - Lista de competências e funções CISO, Técnicos TI e colaboradores

Fonte: Elaboração própria

Este organograma de funções e competências assegura que cada membro da organização compreenda seu papel na proteção das informações, promovendo uma cultura de segurança robusta e eficaz.

6.2. Serviços prestados pela Equipe de Segurança

O organograma apresentado na Figura 3 reflete a estrutura organizacional e os serviços essenciais realizados pela equipe de segurança da informação. A liderança estratégica é atribuída ao CISO, que supervisiona as políticas e estratégias de segurança, coordenando esforços com consultoria externa para garantir alinhamento com as melhores práticas de mercado e conformidade regulatória.

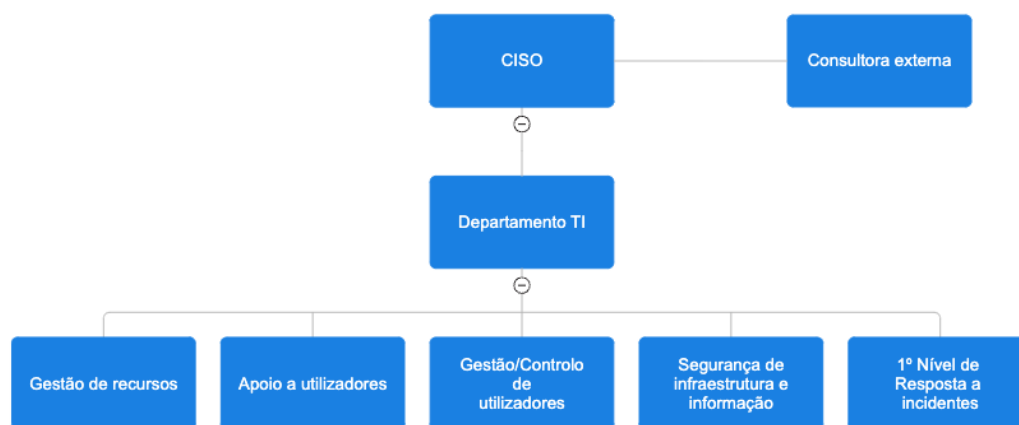


Figura 3 -Organograma dos serviços prestados pela equipa de segurança.

Fonte: Elaboração própria

Gestão de Recursos:

Este serviço envolve a administração eficiente da infraestrutura tecnológica, incluindo redes, equipamentos, e plataformas digitais. O objetivo é garantir que todos os recursos sejam geridos de forma segura, maximizando a eficiência operacional e protegendo contra riscos.

Apoio a Utilizadores:

Focado em fornecer suporte técnico e educacional, esta função auxilia os utilizadores na resolução de problemas relacionados à segurança e promove boas práticas de utilização de sistemas, contribuindo para a conscientização e mitigação de ameaças.

Gestão e Controlo de Utilizadores:

Abrange a supervisão de acessos, a definição de perfis de utilizador, a validação de software e as aprovações necessárias para novas ferramentas ou serviços. Esta equipa atua como a primeira camada de defesa, garantindo que os utilizadores tenham os acessos adequados, minimizando potenciais vulnerabilidades.

Segurança da Infraestrutura e Informação:

Este serviço é responsável pela proteção das redes e dos dados da organização. Inclui a implementação e monitorização de medidas de segurança para proteger contra acessos não autorizados, fuga de informação e outras ameaças cibernéticas.

Primeiro Nível de Resposta a Incidentes:

A equipa é preparada para identificar e responder rapidamente a incidentes de segurança. Este serviço funciona como a linha de frente na mitigação de ataques cibernéticos,

reduzindo o impacto em tempo real e garantindo que as operações da organização sejam mantidas com o mínimo de interrupção.

6.3. Plano de segurança

Uma das funções do CISO é criar e manter um **plano de segurança** estruturado em três anos. Na Figura 4 é descrito o plano estratégico de segurança da informação que será implementado ao longo de três anos, garantindo que os serviços essenciais sejam progressivamente introduzidos e otimizados para atender às necessidades da organização e proteger seus ativos tecnológicos.



Figura 4 - Plano estratégico de segurança da informação

Fonte: Elaboração própria

No primeiro ano irão ser implementados os controlos básicos, ou seja, o foco inicial será estabelecer os controlos de segurança fundamentais.

No segundo ano irá ser efetuado um reforço e automatização dos sistemas de segurança, em que o objetivo é aprimorar os sistemas existentes e automatizar processos críticos.

Já no terceiro ano será dedicado à avaliação e certificação das medidas implementadas para garantir conformidade e melhoria contínua.

Esta abordagem integrada, envolvendo liderança estratégica e execução técnica, garante que a empresa esteja protegida contra ameaças crescentes, promovendo a resiliência organizacional no longo prazo.

6.4. Localização do Serviço de Segurança

A localização do serviço de segurança estará centralizada no Departamento de TI, mas com integração direta a todos os departamentos estratégicos, promovendo uma comunicação eficiente e rápida resposta às necessidades.

7. Metodologia de Análise de Risco

A identificação de riscos é uma etapa essencial na gestão de riscos, pois permite reconhecer e documentar as ameaças e oportunidades que podem impactar os objetivos de uma organização. Para este processo FitTech utiliza diversas técnicas que ajudam a mapear os riscos de forma sistemática e abrangente. Entre as principais técnicas destacam-se as entrevistas com especialistas, as sessões de *brainstorming*, a análise SWOT (Forças, Fraquezas, Oportunidades e Ameaças) e a consulta a bases de dados de eventos passados. Estas ferramentas ajudam a identificar tanto riscos internos, como falhas operacionais, quanto externos, como mudanças no mercado ou ameaças cibernéticas, permitindo à organização priorizar e mitigar os riscos de forma eficaz. [3]

7.1. Identificação de Vulnerabilidades e Ameaças

A identificação de vulnerabilidades e ameaças é uma etapa crucial no processo de gestão de riscos, pois permite à organização compreender as fragilidades e os pontos de exposição que podem comprometer a sua segurança, operação e reputação. As vulnerabilidades referem-se a falhas ou fraquezas nos sistemas, processos ou controlos existentes que podem ser exploradas por agentes maliciosos ou resultar em falhas operacionais. Por outro lado, as ameaças são eventos ou ações externas que podem explorar essas vulnerabilidades, causando danos ou interrupções significativas. [3]

Em seguida procede-se à identificação adequada das vulnerabilidades e ameaças para antecipar riscos e implementar medidas de mitigação eficazes.

Vulnerabilidades:

- Infraestrutura de Rede Vulnerável:
 - **Descrição:** Redes sem proteção adequada, como firewalls, segmentação de rede ou criptografia de dados, que podem ser facilmente invadidas por atacantes.
 - **Impacto:** Acesso não autorizado à rede de produção, podendo levar à sabotagem, roubo de dados ou interrupção de serviços.
- Falta de Monitorização Contínua de Sistemas:
 - **Descrição:** Ausência de ferramentas e processos para monitorizar a integridade e o desempenho dos sistemas em tempo real.
 - **Impacto:** Incapacidade de detetar e responder rapidamente a falhas ou incidentes de segurança que possam afetar a produção.
- Falta de Cifragem de Dados Sensíveis:
 - **Descrição:** Dados críticos, como informações de clientes ou financeiros, não são cifrados tanto em trânsito como em repouso.
 - **Impacto:** Exposição de dados sensíveis a roubo ou acesso não autorizado, especialmente em caso de um ataque cibernético.

Ameaças:

- Ataques informáticos (Malware, Ransomware, Phishing, Etc.)
 - **Vulnerabilidade Associada:** Falta de segurança informática, como sistemas de defesa fracos ou desatualizados.
 - **Descrição:** Tentativas de *hackers* ou grupos maliciosos de aceder ou danificar sistemas críticos, como o sistema de gestão de produção, através de *malware*, *ransomware* ou *phishing*.
 - **Impacto:** Permite que ameaças externas comprometam a integridade e a confidencialidade dos dados.
- Falta de Redundância e Backup de Sistemas
 - **Vulnerabilidade Associada:** Ausência de planos de contingência e falta de sistemas de *backup*.
 - **Descrição:** Falha de *hardware*, erro humano ou falha no sistema de *backup*, que pode resultar na perda de dados importantes e paralisação da produção.
 - **Impacto:** Perda de dados cruciais de produção, dificultando a recuperação de operações após falhas.
- Ataques Físicos (Roubo, Sabotagem, Acesso Não Autorizado)
 - **Vulnerabilidade Associada:** Falta de segurança física no ambiente de produção.
 - **Descrição:** Ameaças físicas, como roubo de dispositivos, sabotagem ou acesso não autorizado, que podem comprometer os sistemas de

gestão de produção e causar perda de dados ou interrupções operacionais.

- **Impacto:** Aumenta o risco de acesso não autorizado ou erro humano que pode comprometer a segurança dos dados e a operação.
- Interrupções no Fornecimento de Energia
 - **Vulnerabilidade Associada:** Falta de sistemas de redundância para fornecimento de energia (ex.: UPS ou geradores).
 - **Descrição:** Falhas no fornecimento de energia, como quedas de energia ou falhas em geradores de backup, que podem parar os sistemas de produção e afetar a continuidade dos negócios.
 - **Impacto:** Interrupções prolongadas nos processos de produção se o equipamento falhar.
- Erros Humanos (Erro Operacional, Manipulação Incorreta de Dados)
 - **Vulnerabilidade Associada:** Falta de formação adequada ou procedimentos operacionais inadequados.
 - **Descrição:** Ameaças internas causadas por erros humanos, como a introdução incorreta de dados, falhas na operação de equipamentos ou não cumprimento de protocolos de segurança.
 - **Impacto:** Pode variar de perdas pequenas (dados corrompidos ou configurações erradas) até falhas significativas no sistema.
- Falhas de Integração entre Sistemas
 - **Vulnerabilidade Associada:** Falhas na integração de sistemas, entre ERP, CRM, e plataformas de produção.
 - **Descrição:** Problemas técnicos que afetam a comunicação entre sistemas e geram inconsistências nos dados, causando erros na produção e atrasos.
 - **Impacto:** Inconsistências nos dados ou falhas na comunicação entre sistemas, resultando em erro de processamento e atrasos na produção.
- Falta de Conformidade com Regulamentos de Qualidade
 - **Vulnerabilidade Associada:** Falta de processos e sistemas para garantir a conformidade com regulamentos.
 - **Descrição:** Alterações nas regulamentações de qualidade ou a falta de fiscalização que podem resultar em não conformidade, o que impacta a reputação e a continuidade da produção.
 - **Impacto:** Pode causar má reputação da empresa e compromete a continuidade da produção.
- Falta de Atualização de Software ou Sistemas Legacy
 - **Vulnerabilidade Associada:** Uso de sistemas desatualizados ou não suportados
 - **Descrição:** Vulnerabilidades de segurança em *software* desatualizado que podem ser exploradas por atacantes para

comprometer os sistemas de produção ou obter acesso a dados sensíveis.

- **Impacto:** Estes sistemas podem conter falhas de segurança conhecidas, não corrigidas, que podem ser exploradas por atacantes ou causar falhas operacionais.

7.2. Cálculo da Probabilidade e do Impacto

Identificadas as vulnerabilidades e ameaças segue-se uma avaliação à probabilidade de ocorrência e o impacto potencial para a organização. Esta abordagem estruturada permite priorizar ações corretivas, garantindo que os riscos mais críticos sejam mitigados de forma eficaz e que a empresa esteja mais bem preparada para enfrentar desafios futuros.

A probabilidade de concretização e o impacto esperado foram calculados segundo os seguintes critérios:

- **Probabilidade de Concretização:** Baseada em dados históricos, análise de tendências e vulnerabilidades atuais.
- **Impacto Esperado:** Determinado pela gravidade das consequências, como interrupções no negócio, perdas financeiras ou danos à reputação da empresa

Na Tabela 2 encontra-se o cálculo da probabilidade de concretização e do impacto esperado.

INCIDENTES	PROBABILIDADE (1 A 5)	IMPACTO (1 A 5)
Ataques Informáticos (Malware, Ransomware, Phishing)	5	5
Falta de Redundância e <i>Backup</i> de Sistemas	3	4
Ataques Físicos (Roubo, Sabotagem, Acesso Não Autorizado)	2	4
Interrupções no Fornecimento de Energia	3	5
Erros Humanos (Erro Operacional, Manipulação Incorreta de Dados)	4	3
Falhas de Integração entre Sistemas	3	4
Falta de Atualização de Software ou Sistemas <i>Legacy</i>	4	5

Tabela 2 - Cálculo da probabilidade e impacto da ocorrência de incidentes

Fonte: Elaboração própria

7.3. Avaliação da Criticidade dos Ativos

A avaliação de criticidade dos ativos será conduzida com base na normativa ISO/IEC 27005:2018 no processo de cálculo de probabilidade e impacto e na elaboração da Matriz de Avaliação de Risco. Para cada ativo, será atribuída uma classificação com base nas métricas utilizadas e apresentadas no quadro da Figura 5:

Probabilidade:

- **Muito alta:** Evento quase certo de ocorrer, várias vezes por ano.
- **Alta:** Evento provável, pelo menos uma vez por ano.
- **Moderada:** Evento possível, pode ocorrer ocasionalmente.
- **Baixa:** Evento improvável, mas não impossível.
- **Rara:** Evento extremamente improvável, mas concebível.

Impacto:

- **Extremo:** Comprometimento total das operações, perdas financeiras severas e danos irreparáveis à reputação da empresa.
- **Grande:** Interrupções significativas, perdas financeiras relevantes e danos moderados à reputação da empresa.
- **Moderado:** Interrupções moderadas com impacto operacional, mas pode ser gerido.
- **Ligeiro:** Pequenos inconvenientes operacionais, impactos mínimos.
- **Insignificante:** Impacto negligenciável ou sem efeito prático nas operações.

		IMPACTO				
		INSIGNIFICANTE 1	LIGEIRO 2	MODERADO 3	GRANDE 4	EXTREMO 5
PROBABILIDADE	MUITO ALTA 5	MÉDIO 5	ALTO 10	ALTO 15	CRÍTICO	CRÍTICO 25
	ALTA 4	BAIXO 4	MÉDIO 8	ALTO 12	ALTO 16	CRÍTICO 20
	MODERADA 3	BAIXO 3	MÉDIO 6	MÉDIO 9	ALTO 12	ALTO 15
	BAIXA 2	BAIXO 2	BAIXO 4	MÉDIO 6	MÉDIO 8	ALTO 10
	RARA 1	BAIXO 1	BAIXO 2	BAIXO 3	BAIXO 4	MÉDIO 5

Figura 5 - Matriz de Avaliação de Risco

Fonte: Elaboração própria

Os ativos a avaliar são os seguintes:

- **Workstations:** Impacto elevado em caso de comprometimento por *malware*.
- **Plataformas digitais:** Altamente críticas, com impacto significativo em operações de negócio.
- **Base de Dados:** Fonte de informação sensível, com impacto elevado em caso de perda ou violação.
- **Equipamentos de produção:** Altamente críticos, com impacto operacional direto.
- **Infraestruturas de redes e servidores:** Críticas para conectividade e continuidade do negócio.
- **Lojas físicas:** Impacto médio, mas relevante no atendimento ao cliente.
- **Armazém:** Impacto médio relacionado com gestão de stock e logística.
- **Colaboradores:** Risco associado a erros humanos e falta de formação.
- **Dados dos colaboradores, clientes e parceiros:** Altamente sensíveis, com impacto na reputação da empresa, e impacto legal significativo.
- **Dados financeiros:** Críticos para a sustentabilidade da organização.

7.4. Definição da Metodologia de Análise de Risco

De forma a garantir a segurança e a resiliência das operações da organização, a FitTech implementa uma metodologia baseada numa **visão integrada do risco**. Esta metodologia considera três principais dimensões: risco estratégico, risco operacional e risco da informação. Cada uma destas dimensões é analisada para identificar potenciais ameaças, impactos e medidas de mitigação, assegurando a resiliência e a continuidade das operações. [3]

Risco Estratégico

Refere-se aos riscos que podem afetar os objetivos de longo prazo e a posição competitiva da empresa no mercado. Os principais riscos identificados são:

- **Mudanças nas preferências dos clientes:** A adoção de novas tecnologias ou alterações nas tendências de fitness podem tornar os produtos ou serviços obsoletos.
 - **Responsável:** Equipa de *Marketing* e Desenvolvimento de Produto
- **Concorrência tecnológica:** Concorrência pode lançar soluções mais avançadas ou a preços mais competitivos.
 - **Responsável:** Equipa de *Marketing* e Desenvolvimento de Produto
- **Dependência de plataformas específicas:** Concentração de operações em plataformas como Shopify ou OutSystems pode criar vulnerabilidades caso ocorram falhas ou mudanças nas condições de serviço.
 - **Responsável:** Equipa de TI e Gestão de Fornecedores
- **Regulamentações e conformidade:** Novas leis, como requisitos adicionais do RGPD, podem aumentar os custos de conformidade e impactar a reputação em caso de não cumprimento.
 - **Responsável:** Departamento Jurídico e de Conformidade

Risco Operacional

Diz respeito a falhas ou interrupções nas operações diárias, que podem comprometer a entrega de produtos e serviços. Os principais riscos identificados são:

- **Interrupção na produção:** Riscos ambientais (catástrofes), falhas nos sistemas IoT ou equipamentos de produção podem atrasar o fabrico.
 - **Responsável:** Equipa de Operações, Engenharia de Produção e Equipa de TI.
- **Gestão de inventário:** Riscos de ruturas de *stock* ou excesso de produtos podem gerar perdas financeiras.
 - **Responsável:** Departamento de Logística

- **Dependência de colaboradores-chave:** Perda de talento técnico ou executivo pode impactar operações críticas.
 - **Responsável:** Departamento de Recursos Humanos (RH)
- **Falhas de integração de sistemas:** Problemas entre o ERP (SAP B1), CRM (*HubSpot*) e plataformas de *e-commerce* podem causar inconsistências nos dados.
 - **Responsável:** Equipe de TI

Risco da Informação

Foca-se na proteção e gestão dos dados críticos da empresa, incluindo dados de clientes, financeiros e industriais. Os principais riscos identificados foram:

- **Ciberataques:** Tentativas de acesso não autorizado a sistemas, como *phishing*, *ransomware* ou ataques DDoS.
 - **Responsável:** Equipe de Segurança da Informação (CISO e Analistas de Segurança)
- **Roubo de dados:** Exposição de informações confidenciais de clientes ou parceiros pode afetar a confiança e resultar em sanções regulatórias.
 - **Responsável:** Equipe de Segurança da Informação e Departamento Jurídico
- **Interrupção de sistemas críticos:** Quedas na *cloud* híbrida ou servidores *on-premises* podem paralisar as operações.
 - **Responsável:** Equipe de Infraestrutura de TI
- **Erro humano:** Configurações incorretas, falta de atualização de sistemas ou descuido no tratamento de dados sensíveis.
 - **Responsável:** Departamento de RH e Equipe de TI

7.5. Realização da Análise de Risco

A análise de risco será efetuada com base nas técnicas acima identificadas onde será utilizada a Matriz de Avaliação de Risco que combina a probabilidade e impacto para classificar o risco total de cada ativo ou serviço e apresentado na Tabela 3.

RISCO	PROBABILIDADE	IMPACTO	NÍVEL DE RISCO (Prob. x Imp.)
Mudanças nas Preferências dos Clientes	4 (Alta)	4 (Grande)	16 (Muito Alto)
Concorrência Tecnológica	4 (Alta)	4 (Grande)	16 (Muito Alto)
Dependência de Plataformas Específicas	3 (Moderada)	4 (Grande)	12 (Alto)
Regulamentações e Conformidade	3 (Moderada)	5 (Extremo)	15 (Alto)
Interrupção na Produção	3 (Moderada)	4 (Grande)	12 (Alto)
Gestão de Inventário	3 (Moderada)	3 (Moderado)	9 (Moderado)
Dependência de Colaboradores-Chave	2 (Baixa)	4 (Grande)	8 (Moderado)
Falhas de Integração de Sistemas	3 (Moderada)	4 (Grande)	12 (Alto)
Ciberataques	5 (Alta)	5 (Extremo)	25 (Muito Alto)
Roubo de Dados	3 (Moderada)	5 (Extremo)	15 (Alto)
Interrupção de Sistemas Críticos	3 (Moderada)	4 (Grande)	12 (Alto)
Erro Humano	4 (Alta)	3 (Moderado)	12 (Alto)
Falta de Redundância e Backup de sistemas	3 (Moderada)	4 (Grande)	12 (Alto)
Ataques Físicos (Roubo, sabotagem, Acesso Não autorizado)	2 (Baixa)	4 (Grande)	8 (Moderado)
Falta de atualização de Software ou Sistemas Legacy	4 (Grande)	5 (Extremo)	20 (Muito Alto)

Tabela 3 - Classificação de risco dos ativos

Fonte: Elaboração própria

Interpretação dos Níveis de Risco:

- **Muito Alto (16-25):** Necessita de medidas de mitigação imediatas e rigorosas.
- **Alto (10-15):** Exige ações prioritárias e monitorização constante.
- **Moderado (5-9):** Monitorização contínua e ações preventivas recomendadas.
- **Baixo (1-4):** Monitorização ocasional, mas sem necessidade de ações urgentes.

7.6. Proposta de Controlo e Mitigação de Riscos

Com base nos resultados, serão implementados os seguintes controlos de segurança apresentados na Tabela 4:

RISCOS	MITIGAÇÃO
Gestão de produção	- Implementação/Melhoramento de redundância em equipamentos; - Monitorização contínua;
Gestão financeira	- Atualização regular de software financeiro; - Controlo de acessos rigoroso com autenticação multifator;
Sistema de pagamentos	- Implementação de autenticação multifator; - Criptografia de ponta a ponta nas transações;
Gestão de produtos	- Restrição de acessos; - Cópias de segurança frequentes com validação periódica.
Distribuição	- Monitorização proativa de rede e servidores; - Backups regulares; - Implementação de firewalls robustos; - Testes de recuperação de desastres
Infraestrutura TI	- Implementação de firewalls robustos; - Monitorização contínua com ferramentas SIEM; - Atualização de sistemas operativos e patches de segurança;
Dados sensíveis	- Encriptação de dados em trânsito e em repouso; - Políticas de acesso baseadas no princípio do privilégio mínimo; - Programas de formação em cibersegurança para colaboradores;
Mudanças nas Preferências dos Clientes	- Investimento contínuo em pesquisa e desenvolvimento para acompanhar tendências de mercado; - Implementação de canais de comunicação com clientes para entender preferências;

RISCOS	MITIGAÇÃO
Concorrência Tecnológica	• Parcerias estratégicas com fornecedores e ginásios; • Monitorização do mercado para identificar novas soluções e tecnologias emergentes;
Dependência de Plataformas Específicas	• Diversificação de plataformas tecnológicas; • Estabelecimento de contratos com cláusulas de continuidade de serviço;
Regulamentações e Conformidade	• Monitorização ativa de alterações regulatórias; • Implementação de auditorias internas de conformidade; • Formação em RGPD e leis aplicáveis;
Gestão de Inventário	• Monitorização em tempo real dos níveis de inventário; • Automatização de reposições com análise preditiva para evitar ruturas;
Colaboradores-Chave	• Criação de planos de sucessão; • Programas de formação contínua e retenção de talentos;
Integração de Sistemas	• Testes regulares de integração entre ERP, CRM e plataformas de e-commerce; • Backups frequentes de dados críticos;
Ciberataques	• Implementação de autenticação multifator; • Monitorização contínua com ferramentas SIEM; • Encriptação de dados sensíveis;
Erro Humano	• Programas de formação em cibersegurança e boas práticas; • Implementação de ferramentas que simplifiquem processos críticos;

Tabela 4 - Propostas de controlo de segurança dos ativos

Fonte: elaboração própria

8. Política de Segurança da Informação

A Política de Segurança da Informação da FitTech tem como objetivo principal a manutenção da Confidencialidade, da Integridade e da Disponibilidade da informação da organização e dos seus clientes, através da redução dos riscos associados à utilização dos seus recursos por aplicação de procedimentos de gestão de risco e ameaças à segurança da informação.

Nesse sentido, a Direção Geral obriga-se a cumprir com a Política de Utilização Aceitável, de a desenhar orientada pela norma ISO/IEC 27001:2022 e de trabalhar na sua melhoria contínua com revisões anuais.

8.1. Perfil atual

Atualmente a empresa FitTech apresenta uma posição sólida no mercado, com uma reputação positiva no ciberespaço e um modelo de negócios inovador. Contudo, ao analisar os processos internos e a infraestrutura tecnológica, torna-se evidente a necessidade de reforçar algumas áreas críticas para garantir a continuidade e segurança das operações, bem como a conformidade com as regulamentações em vigor.

Um dos pontos de atenção mais urgentes é a **formação dos colaboradores**, atualmente inexistente ou mínima. A ausência de programas regulares de capacitação expõe a empresa a riscos significativos, como erros humanos e falta de preparação para lidar com ameaças emergentes.

Os **serviços de backup** também requerem melhorias. O atual sistema não está em conformidade com as melhores práticas de redundância e segurança, colocando em risco a recuperação de dados e a continuidade das operações em caso de falhas ou ataques. Implementar soluções robustas e automatizadas de *backup* é essencial para proteger informações críticas.

Outro ponto crítico é a ausência de um **gestor de palavras-chave** centralizado. A falta de uma ferramenta eficaz para a gestão segura de credenciais expõe a empresa a riscos de comprometimento de contas, especialmente em um ambiente que depende de diversas plataformas digitais.

Os **privilégios atribuídos aos utilizadores** precisam de revisão. A política atual de permissões, sem o princípio do menor privilégio, aumenta o risco de acessos inadequados a informações sensíveis e sistemas críticos. Implementar uma hierarquia clara de acessos e uma revisão periódica dos privilégios é uma medida necessária.

No âmbito da segurança física, os **controles de acesso ao datacenter** são insuficientes. A ausência de medidas robustas para monitorizar e limitar o acesso a este ambiente crítico expõe a infraestrutura a ameaças como roubo, sabotagem ou danos acidentais.

Outro ponto de preocupação é a **ausência de uma política de recuperação de desastres e ciberincidentes**. Atualmente, a empresa não possui um plano formalizado para responder a situações críticas, como falhas sistêmicas, ataques cibernéticos ou interrupções operacionais. Essa lacuna aumenta o tempo de resposta e dificulta a mitigação de danos, colocando em risco a continuidade do negócio.

Por fim, é crucial melhorar a **conformidade com o RGPD**. Embora a empresa já tenha adotado algumas práticas de proteção de dados, lacunas no cumprimento das regulamentações podem resultar em penalidades legais e impactos negativos na reputação.

8.2. Perfil alvo

O objetivo da FitTech não é só consolidar a posição no mercado apenas como líder inovadora, mas também como uma organização que adota as melhores práticas em segurança, gestão de dados e continuidade operacional. Para alcançar este objetivo, é essencial implementar um conjunto de medidas estratégicas que transformarão as atuais lacunas em vantagens competitivas.

No perfil alvo, os **colaboradores** da empresa tornam-se um dos pilares de segurança e eficiência operacional. Programas regulares de **formação em cibersegurança, conformidade regulatória e boas práticas operacionais** são instituídos, garantindo que todos estejam preparados para lidar com ameaças e minimizar erros humanos.

Os **serviços de backup** passam a ser robustos e automatizados, utilizando soluções modernas que garantem a redundância, segurança e a rápida recuperação de dados em caso de falhas ou incidentes. Com sistemas de backup local e na nuvem, a empresa estará preparada para cenários de desastres, mantendo a continuidade das operações sem interrupções significativas.

A gestão de credenciais é fortalecida com a implementação de um **gestor de palavras-chave** centralizado e seguro. Essa ferramenta garante a proteção das credenciais dos colaboradores e permite a auditoria de acessos, reduzindo o risco de comprometimento de contas críticas.

Os **privilégios de acesso** aos sistemas e dados são revistos com base no princípio do menor privilégio. Uma hierarquia clara de permissões é estabelecida, com revisões periódicas para garantir que apenas os utilizadores autorizados acessem informações e sistemas críticos, minimizando o impacto de possíveis incidentes internos ou externos.

No âmbito da segurança física, o **datacenter** é protegido por um sistema abrangente de **controle de acessos**, incluindo medidas como autenticação biométrica, vigilância por vídeo e monitorização em tempo real. Essas melhorias asseguram que apenas pessoal autorizado possa aceder ao ambiente crítico.

Para aumentar a resiliência operacional, a empresa adota uma **política robusta de recuperação de desastres e ciberincidentes**. Esse plano formalizado inclui procedimentos claros para resposta a emergências, equipas treinadas e soluções de tecnologia que garantem a rápida retomada das operações, reduzindo ao mínimo os impactos financeiros e de reputação da empresa.

No que diz respeito à conformidade, a empresa alcança **aderência total ao RGPD** e outras regulamentações aplicáveis. Auditorias regulares, ferramentas de monitoramento e processos internos alinhados às exigências legais garantem a proteção de dados sensíveis, fortalecendo a confiança dos clientes e parceiros.

8.3. Enumeração das Políticas de segurança

De maneira a garantir a segurança da informação na FitTech serão incluídas algumas políticas de segurança como:

- Formar colaboradores
- Serviços de *backup*
- Gestão de palavras-passe
- Controlos de acesso
- Notificação de incidentes
- RGPD
- Recuperação de desastres
- ISO/IEC 27001:2022

8.3.1. Política de Formação em Segurança da Informação

1. Objetivo

Garantir que todos os colaboradores da organização estejam cientes das melhores práticas de segurança da informação, compreendam os riscos associados às suas atividades e contribuam para a proteção dos ativos de informação, em conformidade com a norma ISO/IEC 27001:2022.

2. Âmbito

Esta política aplica-se a todos os colaboradores, incluindo funcionários, prestadores de serviços, parceiros e estagiários que tenham acesso a sistemas, informações ou infraestruturas da organização.

3. Princípios Fundamentais

- **Sensibilização e Educação:** Garantir que todos os colaboradores compreendam a importância da segurança da informação.
- **Mitigação de Erros Humanos:** Reduzir o impacto de erros humanos através de formação contínua.
- **Conformidade Regulamentar:** Assegurar que todos os colaboradores estejam em conformidade com as exigências legais e normativas existentes no RGPD e na ISO/IEC 27001:2022.

4. Orientações para Formação em Segurança da Informação

4.1. Conteúdo da Formação:

- Os programas de formação devem incluir, mas não se limitar a:
 - Conceitos básicos de segurança da informação e cibersegurança.
 - Reconhecimento de ameaças comuns, como *phishing*, *malware* e *ransomware*.
 - Boas práticas para proteção de dados e gestão de credenciais (ex.: utilização de gestores de palavras-passe).
 - Políticas internas de segurança, incluindo backup, controlo de acesso e conformidade com o RGPD.
 - Procedimentos para reportar incidentes de segurança.

4.2. Frequência da Formação

- **Formação Inicial:** Todos os novos colaboradores devem receber formação em segurança da informação no início das suas funções.
- **Formação Contínua:** Realizar formações anuais ou semestrais para reforçar os conhecimentos e introduzir atualizações.
- **Formação Adicional:** Organizar sessões específicas em resposta a novas ameaças, alterações regulatórias ou incidentes de segurança.

4.3. Métodos de Formação

- **Presencial e Online:** Utilização de plataformas de *e-learning*, *workshops* e sessões presenciais.

- **Simulações Práticas:** Testes de *phishing* e exercícios de resposta a incidentes para avaliar a eficácia da formação.
- **Material de Apoio:** Distribuição de manuais, guias rápidos e *checklists* sobre segurança da informação.

4.4. Avaliação de Conhecimentos

- Realizar testes e avaliações periódicas para verificar a compreensão dos conceitos abordados.
- Implementar métricas para medir a eficácia da formação e identificar áreas de melhoria.

5. Responsabilidades

5.1. Gestão de Recursos Humanos

- Incorporar a formação em segurança da informação nos processos de integração de novos colaboradores.
- Coordenar a agenda e os registos de formação.

5.2. Gestor de Segurança da Informação

- Desenvolver e supervisionar os conteúdos das formações.
- Garantir que os programas de formação estão orientados às melhores práticas da ISO/IEC 27001:2022.

5.3. Colaboradores

- Participar ativamente nas formações e aplicar os conhecimentos adquiridos nas suas atividades diárias.
- Reportar qualquer incidente ou suspeita de violação de segurança à equipa responsável.

6. Monitorização e Melhoria

- Registrar todas as sessões de formação realizadas, incluindo datas, conteúdos e participantes.
- Recolher *feedback* dos participantes para ajustar e melhorar os programas de formação.
- Realizar auditorias periódicas para avaliar a conformidade com esta política.

7. Penalidades por Não Conformidade

- O não cumprimento desta política pode resultar em ações disciplinares, conforme definido no regulamento interno da organização, e em

consequências legais caso haja negligência que resulte em violações de segurança.

8. Revisão e Atualização da Política

- Esta política será revista anualmente ou sempre que houver alterações significativas nos requisitos regulatórios, nas ameaças identificadas ou nos processos internos.

Data de Aprovação: 01/01/2025

Revisão Anterior: Sem revisão

Próxima Revisão: 01/01/2026

8.3.2. Gestão de Palavra-Passe

1. Objetivo

Estabelecer orientações e práticas para a criação, utilização e gestão segura de passwords, garantindo a proteção dos sistemas, dados e recursos da organização contra acessos não autorizados, em conformidade com a norma ISO/IEC 27001:2022.

2. Âmbito

Esta política aplica-se a todos os colaboradores, prestadores de serviços, parceiros e qualquer pessoa que tenha acesso aos sistemas e recursos de informação da organização.

3. Princípios Fundamentais

- **Confidencialidade:** Garantir que apenas utilizadores autorizados tenham acesso aos recursos necessários para as suas funções.
- **Integridade:** Proteger as passwords contra alterações ou comprometimentos não autorizados.
- **Disponibilidade:** Garantir que as passwords sejam acessíveis e utilizáveis apenas pelos seus titulares autorizados.

4. Diretrizes para Gestão de Passwords

4.1. Criação de Passwords

- **Complexidade:** Deve ter, no mínimo, 12 caracteres.
- Incluir letras maiúsculas, letras minúsculas, números e caracteres especiais.
- Não utilizar palavras comuns, sequências óbvias (ex.: "123456" ou "qwerty") ou informações pessoais (ex.: datas de nascimento).
- **Unicidade:** Cada conta deve ter uma password única.

- Passwords não devem ser reutilizadas em sistemas diferentes.

4.2. Armazenamento de Passwords

- **Gestor de Passwords:** Os colaboradores devem utilizar um gestor de passwords aprovado pela organização para armazenar e gerir credenciais de forma segura.
- **Proibição de Registos Inseguros:** É estritamente proibido guardar passwords em locais não seguros, como notas físicas, documentos digitais desprotegidos ou partilhados.

4.3. Alteração de Passwords

- **Periodicidade:** Alterar passwords críticas a cada 90 dias, ou conforme determinado pelo Gestor de Segurança da Informação (GSI).
- **Comprometimento:** Alterar imediatamente qualquer password que se suspeite estar comprometida ou exposta.

4.4. Utilização de Passwords

- **Confidencialidade:** As passwords são pessoais e intransferíveis. É proibido partilhá-las com terceiros, incluindo colegas ou gestores.
- **Autenticação de Dois Fatores (2FA):** Sempre que possível, a utilização de passwords deve ser complementada com mecanismos de autenticação adicional, como códigos enviados por SMS, aplicações de autenticação ou dispositivos biométricos.

4.5. Acesso e Revogação

- **Novos Utilizadores:** Passwords temporárias devem ser atribuídas inicialmente e obrigatoriamente alteradas no primeiro acesso.
- **Saída de Colaboradores:** Todas as contas associadas a um colaborador devem ser desativadas ou revistas imediatamente após o término do vínculo com a organização.

5. Responsabilidades

5.1. Gestor de Segurança da Informação

- Desenvolver, implementar e monitorizar esta política.
- Realizar auditorias periódicas para garantir a conformidade com a gestão de passwords.
- Promover campanhas de sensibilização e formação sobre boas práticas na gestão de passwords.

5.2. Colaboradores

- Criar e gerir passwords de acordo com esta política.
- Reportar imediatamente ao GSI qualquer suspeita de comprometimento de passwords.

6. Monitorização e Melhoria

- **Auditorias Regulares:** Realizar revisões periódicas para identificar potenciais fraquezas na gestão de passwords.
- **Teste de Conformidade:** Implementar testes simulados, como auditorias de segurança, para verificar a robustez das práticas de gestão de passwords.
- **Atualizações:** Adaptar esta política sempre que surgirem novas ameaças ou tecnologias que possam melhorar a segurança.

7. Penalidades por Não Conformidade

O incumprimento desta política pode resultar em ações disciplinares, conforme definido no regulamento interno da organização, além de potenciais sanções legais em casos de negligência grave.

8. Revisão e Atualização da Política

Esta política será revista anualmente ou sempre que houver alterações relevantes na infraestrutura, nas ameaças identificadas ou nos requisitos regulatórios.

Data de Aprovação: 01/01/2025

Revisão Anterior: Sem revisão

Próxima Revisão: 01/01/2026

8.3.3. Políticas de Acesso Lógico

1. Objetivo

Estabelecer orientações para a implementação, gestão e monitorização de controlos de acesso lógico, assegurando que os recursos de informação são acedidos exclusivamente por utilizadores autorizados, em conformidade com a norma ISO/IEC 27001.

2. Âmbito

Esta política aplica-se a todos os sistemas de informação, aplicações, redes e dispositivos pertencentes à organização, assim como a todos os colaboradores, parceiros e terceiros que acedam a esses recursos.

3. Princípios Fundamentais

- **Confidencialidade:** Garantir que a informação é acessível apenas por pessoas autorizadas.
- **Integridade:** Assegurar que os dados não são alterados ou manipulados de forma não autorizada.
- **Disponibilidade:** Assegurar que os recursos de informação estão acessíveis quando necessários, por utilizadores autorizados.

4. Diretrizes para Controlo de Acesso Lógico

4.1. Princípios de Atribuição de Acessos

- **Princípio do Mínimo Privilégio:** Cada utilizador deve ter acesso apenas aos recursos necessários para desempenhar as suas funções.
- **Separação de Funções:** Implementar restrições para evitar que uma única pessoa tenha controlo total sobre funções críticas.

4.2. Gestão de Contas de Utilizador

- **Criação de Contas:** Contas de utilizador devem ser criadas apenas após autorização formal do responsável hierárquico e do GSI.
- **Gestão de Contas Inativas:** Contas que permaneçam inativas por mais de 90 dias devem ser suspensas ou eliminadas, conforme aplicável.
- **Desativação de Contas:** Contas de utilizadores que deixem a organização ou mudem de função devem ser imediatamente desativadas.

4.3. Autenticação

- **Políticas de Passwords:** Implementar requisitos de complexidade, unicidade e periodicidade de alteração de passwords.
- **MFA:** Utilizar MFA para acessos a sistemas críticos ou sensíveis.
- **Sessões Inativas:** Implementar bloqueio automático de sessões após 15 minutos de inatividade.

4.4. Gestão de Acessos Privilegiados

- Contas com privilégios administrativos devem ser restritas a utilizadores estritamente necessários.
- Atividades realizadas com contas privilegiadas devem ser monitorizadas e registadas.

4.5. Registo e Monitorização de Acessos

- **Auditoria de Acessos:** Registrar todas as tentativas de acesso, bem como acessos bem-sucedidos e não autorizados.
- **Monitorização Contínua:** Utilizar ferramentas de monitorização para detetar e alertar sobre atividades suspeitas.

4.6. Revisão de Acessos

Realizar revisões periódicas (pelo menos semestrais) das permissões de acesso para garantir conformidade com os requisitos de segurança e eliminar acessos desnecessários.

5. Responsabilidades

5.1. Gestor de Segurança da Informação

- Desenvolver, implementar e monitorizar esta política.
- Realizar auditorias periódicas de acessos e conformidade.

5.2. Responsáveis por Departamentos

- Validar solicitações de acesso e garantir que os acessos concedidos são adequados às funções dos utilizadores.

5.3. Colaboradores

- Utilizar as credenciais de acesso exclusivamente para fins profissionais.
- Reportar imediatamente quaisquer anomalias ou acessos não autorizados ao GSI.

6. Monitorização e Melhoria

- **Auditorias Regulares:** Realizar auditorias internas para verificar a conformidade com esta política e identificar áreas de melhoria.
- **Atualizações Tecnológicas:** Avaliar periodicamente as ferramentas de controlo de acesso para adotar soluções mais eficazes.

7. Penalidades por Não Conformidade

O incumprimento desta política pode resultar em sanções disciplinares, de acordo com o regulamento interno da organização, bem como em responsabilidade legal, dependendo da gravidade da violação.

8. Revisão e Atualização da Política

Esta política será revista anualmente ou sempre que houver alterações significativas nos sistemas de informação ou nas ameaças de segurança identificadas.

Data de Aprovação: 01/01/2025

Revisão Anterior: Sem revisão

Próxima Revisão: 01/01/2026

8.3.4. Políticas de Backup

1. Objetivo

Estabelecer orientações e procedimentos para a criação, gestão e proteção de cópias de segurança (backups) dos dados e sistemas críticos da organização, assegurando a continuidade do negócio e a recuperação de informações em caso de falhas, incidentes ou desastres.

2. Âmbito

Esta política aplica-se a todos os sistemas, aplicações, bases de dados e informações críticas da organização, bem como a todos os colaboradores e terceiros que participem na gestão de backups.

3. Princípios Fundamentais

- **Disponibilidade:** Garantir que os backups estão acessíveis em situações de necessidade, como falhas de sistemas ou ciberincidentes.
- **Confidencialidade:** Proteger os dados de backup contra acessos não autorizados.
- **Integridade:** Assegurar que os dados de backup estão completos e livres de alterações ou corrupção.

4. Orientações para a Gestão de Backups

4.1. Identificação de Dados Críticos

- Identificar e classificar os dados e sistemas críticos que devem ser incluídos no plano de backup, incluindo:
 - Dados financeiros, de clientes, e de colaboradores.
 - Sistemas operativos e aplicações essenciais para o negócio.
 - Configurações de sistemas e redes.

4.2. Frequência e Retenção de Backups

- Realizar backups regulares, com periodicidade baseada na criticidade dos dados:
 - Dados operacionais: Diariamente.
 - **Dados menos críticos:** Semanalmente ou mensalmente.
- Definir políticas de retenção de backups:
 - **Backups diários:** Retenção mínima de 7 dias.
 - **Backups semanais:** Retenção mínima de 4 semanas.
 - **Backups mensais:** Retenção mínima de 12 meses.

4.3. Armazenamento de Backups

- Implementar armazenamento em múltiplos locais para proteção contra desastres, incluindo:
 - **On-site:** Para acessos rápidos em casos de falhas menores.
 - **Off-site:** Para proteção contra desastres físicos, como incêndios ou inundações.
 - **Cloud:** Para maior redundância e acessibilidade.

4.4. Segurança dos Backups

- **Cifragem de Dados:** Todos os backups devem ser cifrados utilizando padrões de segurança robustos (ex.: AES-256).
- **Controlo de Acessos:** Restringir o acesso aos backups apenas a utilizadores autorizados.
- **MFA:** Exigir MFA para aceder aos sistemas de backup.

4.5. Testes de Recuperação

- Realizar testes periódicos de recuperação para garantir que os backups estão funcionais e que os dados podem ser restaurados de forma eficiente.
- Frequência mínima de testes: Semestral.

4.6. Monitorização e Registo

- Monitorizar continuamente os processos de backup para identificar falhas ou inconsistências.
- Manter registos detalhados de todas as operações de backup, incluindo:
 - Data e hora do backup.
 - Sistemas e dados incluídos.
 - Resultados de testes de recuperação.

5. Responsabilidades

5.1. Gestor de Segurança da Informação

- Desenvolver, implementar e supervisionar a política de backup.
- Garantir que os backups estão orientados com os requisitos da norma ISO/IEC 27001.

5.2. Equipe de TI

- Executar e monitorizar os backups conforme a política.
- Realizar testes de recuperação e relatar quaisquer problemas ao GSI.

5.3. Colaboradores

- Garantir que os dados críticos sob sua responsabilidade são incluídos nos processos de backup.
- Reportar qualquer incidente ou necessidade de recuperação ao GSI.

6. Monitorização e Melhoria

- Realizar auditorias regulares (pelo menos anuais) para avaliar a eficácia da política de backup e identificar áreas de melhoria.
- Atualizar a política em resposta a mudanças tecnológicas, requisitos regulatórios ou incidentes de segurança.

7. Penalidades por Não Conformidade

O incumprimento desta política pode resultar em sanções disciplinares, de acordo com o regulamento interno da organização, além de possíveis implicações legais.

8. Revisão e Atualização da Política

Esta política será revista anualmente ou sempre que houver alterações significativas nos sistemas ou nos requisitos de segurança.

Data de Aprovação: 01/01/2025

Revisão Anterior: Sem revisão

Próxima Revisão: 01/01/2026

8.3.5. Política de Notificação de incidentes de Segurança da Informação

1. Objetivo

Garantir que todos os colaboradores da organização estejam preparados para identificar, reportar e responder a incidentes de segurança da informação, protegendo os ativos da organização e minimizando os impactos de potenciais ameaças, em conformidade com a norma ISO/IEC 27001:2022.

2. Âmbito

Esta política aplica-se a todos os colaboradores, incluindo funcionários, prestadores de serviços, parceiros e estagiários que tenham acesso a sistemas, informações ou infraestruturas da organização.

3. Princípios Fundamentais

- **Rápida Resposta:** Garantir que todos os incidentes sejam reportados e tratados de forma imediata.
- **Registo e Transparência:** Manter registos detalhados dos incidentes para apoiar a melhoria contínua.
- **Conformidade Regulamentar:** Assegurar que os procedimentos de notificação de incidentes estejam alinhados com as exigências legais e normativas, incluindo a ISO/IEC 27001:2022.

4. Orientações para a Notificação de Incidentes

4.1. Identificação e Registo

- Todos os colaboradores devem ser capazes de identificar potenciais incidentes de segurança, tais como:
 - Acessos não autorizados a sistemas ou informações;
 - Perda ou roubo de dispositivos que contenham dados sensíveis;
 - Atividades suspeitas, como tentativas de phishing ou malware.
- O incidente deve ser registado imediatamente num sistema apropriado, detalhando:
 - Data e hora da ocorrência;
 - Natureza do incidente;
 - Sistemas ou dados afetados;
 - Impacto inicial percebido.

4.2. Comunicação Interna e Externa

- **Interna:** Notificar a equipa de segurança da informação e os gestores responsáveis.
 - Comunicar às equipas envolvidas ou potencialmente afetadas.
- **Externa:** Informar as autoridades competentes, como previsto por regulamentos, em casos de violações significativas.
 - Comunicar a clientes ou parceiros impactados, quando necessário, respeitando as políticas de privacidade.

4.3. Resolução de Incidentes

- A equipa de segurança deve realizar:
 - Análise detalhada do incidente para determinar a causa raiz;
 - Implementação de medidas de contenção e resolução;
 - Identificação de ações corretivas e preventivas.

4.4. Avaliação e lições aprendidas

- Realizar uma revisão pós-incidente para:
 - Documentar lições aprendidas;
 - Atualizar os procedimentos internos e melhorar a resposta futura.

5. Responsabilidades

5.1. Colaboradores

- Identificar e reportar incidentes de segurança de forma imediata;
- Participar em formações e aplicações de melhores práticas de segurança.

5.2. Equipa de Segurança da Informação

- Garantir que os incidentes sejam registados e tratados de acordo com os procedimentos;
- Realizar investigações e implementar soluções eficazes.

5.3. Gestão da Organização

- Apoiar recursos para a resposta a incidentes;
- Garantir o cumprimento desta política.

6. Monitorização e Melhoria

- Realizar auditorias regulares aos registos de incidentes para verificar conformidade e identificar tendências;
- Atualizar a política e os procedimentos de notificação com base em lições aprendidas e evolução das ameaças.

7. Penalidades por Não Conformidade

O não cumprimento desta política pode resultar em medidas disciplinares, de acordo com o regulamento interno da organização, e em ações legais em casos graves.

8. Revisão e Atualização da Política

Esta política será revista anualmente ou sempre que houver alterações significativas nos requisitos regulamentares, ameaças identificadas ou processos internos.

Data de Aprovação: 01/01/2025

Revisão Anterior: Sem revisão

Próxima Revisão: 01/01/2026

8.3.6. Política de conformidade com o RGPD

1. Objetivo

Garantir que a organização cumpre com os requisitos estabelecidos pelo RGPD, protegendo os direitos e liberdades dos titulares de dados pessoais e promovendo boas práticas no tratamento de dados.

2. Âmbito

Esta política aplica-se a todos os colaboradores, incluindo funcionários, prestadores de serviços, parceiros e estagiários que realizem atividades de tratamento de dados pessoais no âmbito das operações da organização.

3. Princípios Fundamentais

- **Licitude, Lealdade e Transparência:** Os dados pessoais devem ser tratados de forma lícita, leal e transparente em relação ao titular.
- **Limitação das Finalidades:** Os dados devem ser recolhidos para fins específicos, explícitos e legítimos e não ser tratados de forma incompatível com essas finalidades.
- **Minimização de Dados:** Apenas serão tratados os dados estritamente necessários para as finalidades previstas.
- **Exatidão:** Os dados devem ser exatos e atualizados sempre que necessário.

- **Limitação da Conservação:** Os dados serão conservados apenas pelo tempo necessário para as finalidades do tratamento.
- **Segurança:** Os dados serão tratados de forma a garantir a sua segurança, incluindo proteção contra acesso não autorizado, perda, destruição ou dano accidental.

4. Orientações para a Conformidade com o RGPD

4.1. Registo e Gestão de Dados Pessoais

- Manter um registo atualizado das atividades de tratamento de dados pessoais, incluindo:
 - Finalidade do tratamento;
 - Categoria dos titulares e dados tratados;
 - Base legal para o tratamento;
 - Períodos de conservação.

4.2. Direitos dos Titulares de Dados

- Garantir que os titulares possam exercer os seus direitos, incluindo:
 - Acesso aos dados pessoais;
 - Retificação ou apagamento dos dados;
 - Limitação do tratamento;
 - Portabilidade dos dados;
 - Oposição ao tratamento;
 - Direito de apresentar reclamação junto da autoridade de controlo (CNPD).

4.3. Bases Legais para o Tratamento

- Identificar e documentar a base legal apropriada para cada atividade de tratamento, tais como:
 - Consentimento do titular;
 - Cumprimento de obrigações legais;
 - Execução de contratos;
 - Interesses legítimos da organização.

4.4. Medidas de Segurança

- Implementar medidas técnicas e organizativas adequadas para proteger os dados pessoais, incluindo:
 - Controlo de acesso e autenticação;
 - Cifração e pseudonimização de dados;
 - Monitorização e resposta a incidentes de segurança.

4.5. Notificação de Violações de Dados

- Notificar a CNPD no prazo de 72 horas após a deteção de uma violação de dados pessoais, quando aplicável;
- Informar os titulares de dados, caso a violação apresente elevado risco para os seus direitos e liberdades.

5. Responsabilidades

5.1. Responsável pelo Tratamento

- Assegurar que todas as atividades de tratamento estejam em conformidade com o RGPD;
- Supervisionar a implementação de medidas de segurança e processos internos.

5.2. Encarregado de Proteção de Dados (DPO)

- Monitorizar a conformidade da organização com o RGPD;
- Ser ponto de contacto para a CNPD e para os titulares de dados.

5.3. Colaboradores

- Seguir as políticas e procedimentos internos relativos ao tratamento de dados;
- Reportar qualquer incidente ou suspeita de violação de dados.

6. Monitorização e Melhoria

- Realizar auditorias regulares para verificar a conformidade com esta política;
- Recolher feedback para melhorar os processos e procedimentos relativos ao tratamento de dados pessoais.

7. Penalidades por Não Conformidade

O incumprimento desta política pode resultar em sanções disciplinares e multas aplicadas pela CNPD, de acordo com o RGPD.

8. Revisão e Atualização da Política

Esta política será revista anualmente ou sempre que houver alterações significativas nos requisitos regulatórios ou nas atividades de tratamento de dados.

Data de Aprovação: 01/01/2025

Revisão Anterior: Sem revisão

Próxima Revisão: 01/01/2026

8.3.7. Política de Recuperação de Desastres

1. Objetivo

Garantir a continuidade das operações da organização em caso de desastres que comprometam os sistemas, dados ou infraestruturas, minimizando o impacto nas atividades e assegurando a recuperação rápida e eficaz dos recursos essenciais.

2. Âmbito

Esta política aplica-se a todos os sistemas, dados, infraestruturas e operações da organização, bem como aos colaboradores, prestadores de serviços e parceiros que desempenhem funções relacionadas com a continuidade do negócio.

3. Princípios Fundamentais

- **Prevenção:** Identificar riscos e implementar medidas para minimizar a probabilidade de desastres.
- **Prontidão:** Manter planos de recuperação atualizados e realizar testes regulares.
- **Continuidade:** Garantir a manutenção dos serviços essenciais durante o período de recuperação.
- **Melhoria Contínua:** Rever e atualizar a política com base em lições aprendidas.

4. Orientações para a Recuperação de Desastres

4.1. Avaliação de Riscos e Impactos

- Identificar e documentar ameaças potenciais, como:
 - Falhas de sistemas ou hardware;
 - Ciberataques;
 - Desastres naturais (inundações, sismos);
 - Interrupções de energia ou comunicação.
- Avaliar os impactos potenciais em sistemas críticos e no negócio.

4.2. Plano de Recuperação de Desastres (PRD)

- Definir procedimentos claros para:
 - Backup e restauração de dados;
 - Recuperação de sistemas e infraestrutura;
 - Comunicação interna e externa durante um desastre.
- Estabelecer tempos máximos de inatividade permitidos (RTO) e perdas de dados aceitáveis (RPO).

4.3. Backups e Redundância

- Implementar sistemas de backup regulares e automáticos para:
 - Dados críticos da organização;
 - Configurações e registros de sistemas.
 - Assegurar a existência de redundância em infraestruturas essenciais.

4.4. Testes e Simulações

- Realizar testes regulares do PRD para:
 - Verificar a eficácia dos procedimentos;
 - Identificar lacunas ou melhorias necessárias;
 - Assegurar que os colaboradores conhecem os seus papéis no plano.

4.5. Comunicação durante Desastres

- Designar responsáveis pela comunicação interna e externa;
- Garantir que as partes interessadas, incluindo colaboradores, clientes e parceiros, sejam informadas de forma clara e tempestiva.

5. Responsabilidades

5.1. Gestor de Recuperação de Desastres

- Coordenar a elaboração, implementação e revisão do PRD;
- Liderar a resposta durante um desastre.

5.2. Equipa de TI

- Garantir a execução de backups regulares;
- Implementar medidas de segurança e redundância em sistemas.

5.3. Colaboradores

- Cumprir os procedimentos definidos no PRD;
- Reportar qualquer incidente ou situação de risco.

6. Monitorização e Melhoria

- Rever regularmente o PRD com base em:
 - Resultados de testes e simulações;
 - Incidentes ocorridos e respetiva resposta;
 - Alterações nos riscos ou operações da organização.

7. Penalidades por Não Conformidade

O incumprimento desta política pode resultar em sanções disciplinares e em perdas financeiras ou reputacionais para a organização.

8. Revisão e Atualização da Política

Esta política será revista anualmente ou sempre que houver alterações significativas nas ameaças identificadas, nos sistemas ou nas atividades da organização.

Data de Aprovação: 01/01/2025

Revisão Anterior: Sem revisão

Próxima Revisão: 01/01/2026

8.3.8. ISO/IEC 27001:2022

A certificação da FitTech na ISO/IEC 27001:2022 garante que a empresa segue as melhores práticas internacionais em gestão de segurança da informação. O objetivo de ser certificado na norma é o de reforçar a confiança de clientes e parceiros, demonstrando o compromisso da empresa com a segurança da informação.

8.4. Classificação de ativos

A política de classificação é desenvolvida para garantir a proteção adequada de todos os ativos da FitTech, esta política terá como objetivos a identificação, categorização e implementação de medidas de proteção conforme a criticidade do ativo.

8.4.1. Critérios de Classificação

Na classificação dos ativos, é fundamental considerar se o ativo é um ativo físico, lógico ou informacional. Para além disso, é necessário avaliar o impacto que a indisponibilidade, perda ou roubo desse ativo pode ter no funcionamento do negócio. Deve-se também ter em conta o nível de sensibilidade do ativo, verificando se contém informações confidenciais que apenas podem ser acedidas por um número restrito de pessoas. Por fim, é necessário garantir que o ativo cumpre todos os requisitos legais e regulamentares, como o estabelecido no RGPD, de forma a assegurar o tratamento adequado de dados pessoais e a proteção da privacidade.

8.4.2. Categorias de Classificação

Os ativos vão ser classificados nas seguintes categorias:

- **Público:** Dados e recursos que podem ser divulgados sem causar impacto à empresa.

- **Interno:** Informações de uso exclusivo dos colaboradores, com impacto limitado em caso de exposição
- **Confidencial:** Recursos que exigem proteção devido à sua relevância estratégica ou sensibilidade
- **Restrito:** Ativos de maior criticidade, como planos estratégicos, dados biométricos e sistemas de produção.

8.4.3. Diretrizes de proteção por categoria

As diretrizes de proteção por categoria serão:

- **Público:** Monitorização básica
- **Interno:** Acesso limitado a colaboradores
- **Confidencial:** Encriptação, autenticação multifator e controlos de acesso rigorosos
- **Restrito:** Monitorização continua, auditorias frequentes, todos os pontos da categoria **Confidencial**, mas com um acesso a um número muito limitado de utilizadores.

8.4.4. Aplicação da política de classificação

Os ativos da FitTech serão classificados da seguinte maneira:

- **Público:** Materiais de *marketing*, catálogos de produtos, guias e manuais.
- **Interno:** Relatórios operacionais, ferramentas de gestão de projetos.
- **Confidencial:** Informações financeiras, relatórios internos, estratégias de negócios, protótipos, planos de desenvolvimento.
- **Restrito:** Infraestrutura de rede, dados de clientes, equipamentos de produção.

9. Arquitetura de Segurança Perimétrica

A arquitetura e segurança perimétrica desempenha um papel fundamental na defesa contra ameaças externas e na garantia que os fluxos de informação dentro da organização permaneçam seguros, íntegros e controlados. O objetivo deste plano é definir uma abordagem estruturada para proteger os seus serviços e ativos críticos da empresa, controlar zonas de segurança, implementar tecnologias de monitorização e deteção de ameaças.

9.1. Análise de Riscos

Principais ameaças:

- Acesso não autorizado
- Ataques cibernéticos

Ativos críticos:

- Infraestrutura de TI
- Sistemas de produção
- Dados
- Armazém

9.2. Controlos de Zonas Segurança

A FitTech será dividida nas seguintes zonas de segurança:

Zona Pública:

- Sistemas voltados para o exterior
- Acesso à internet é permitido, mas com restrições

Zona de Produção:

- Sistema de fabrico e dispositivos IoT
- Comunicação controlada com outras zonas e acesso restrito

Zona Administrativa:

- Contém sistemas de gestão empresarial
- Comunicação limitada com zonas externas

Zonas de Desenvolvimento:

- Ambiente de testes e de desenvolvimento
- Separada da produção para evitar interferências

Zona do Armazém:

- Armazenamento dos produtos criados
- Acesso restrito

Deteção de anomalias com origem no exterior e entre zonas:

- Implementação de um SIEM para monitorização contínua de *logs* e tráfego
- Análise comportamental para identificar atividades suspeitas
- Uso de *firewalls* para proibir acesso a alguns *websites* e bloquear tráfego indesejado

9.3. Controlo de Acessos

Acesso à internet e entre zonas:

- Configuração de *firewalls* NGFW (Next Generation Firewall)
- DMZ:
 - Zona que hospeda serviços acessíveis externamente como API
 - Criar regras que restringem a comunicação com a zona interna
- VPN
 - Acesso seguro para os empregados
- MFA obrigatória

Para minimizar interações serão separadas as redes de desenvolvimento e redes administrativas para evitar ataques de movimento lateral.

Já na parte física, como na zona de produção e no armazém e outros edifícios, serão implementados dispositivos de controlo de acesso com reconhecimento facial para autorizar a entrada nos edifícios. Além disso, os edifícios estarão equipados com sistemas de alarme e câmaras de videovigilância, garantindo a monitorização contínua e reforçando a segurança contra acessos não autorizados ou incidentes.

9.3.1. Alarme e Videovigilância

O sistema de alarme e videovigilância será instalado por uma empresa externa, esta empresa deve respeitar os seguintes requisitos:

- O sistema de alarme será configurado para permitir a ativação e desativação através de uma aplicação móvel, proporcionando maior flexibilidade e conveniência, sendo que apenas algumas pessoas da empresa terão acesso à mesma aplicação. Esta funcionalidade será especialmente útil para autorizar acessos aos edifícios fora do horário laboral.
- O sistema deve salvaguardar a privacidade dos trabalhadores, garantindo a ausência de camaras em locais privados.
- As gravações devem ser guardadas pela empresa externa garantindo a confidencialidade, integridade e disponibilidade das gravações.

9.3.2. Reconhecimento Facial

O sistema de reconhecimento facial será instalado por uma empresa externa, esta empresa deve respeitar os seguintes requisitos:

- O sistema não deverá permitir a utilização de fotografias ou imagens estáticas para aceder aos edifícios, garantindo maior segurança contra tentativas de fraude.
- O sistema de reconhecimento facial deve funcionar em condições de pouca visibilidade por exemplo quando está de noite ou em ambientes mal iluminados.
- Deverá existir uma alternativa de acesso através de um código de 6 dígitos, com um limite máximo de tentativas para evitar acessos não autorizados, garantindo assim uma opção de entrada em caso de falha do reconhecimento facial.
- Os dados biométricos dos trabalhadores e utilizadores devem ser guardados de forma segura, num formato que não permita a recriação dos dados biométricos originais.

9.4. Fluxos de Comunicação e Controlo

Na FitTech os fluxos de comunicação são encriptados com TLS 1.3 ou DTLS para garantir a confidencialidade e proteger as comunicações tanto entre zonas como nas comunicações com os servidores.

Para monitorar o fluxo e garantir que não existe tráfego malicioso serão configurados sistemas IDS/IPS para detetar e prevenir o mesmo.

10. Política de Uso Aceitável (PUA)

Através da Política de Uso Aceitável a organização pretende garantir a utilização responsável dos seus recursos (físicos e digitais), definir os requisitos de segurança e as práticas a aplicar na gestão da informação digital, e identificar as fronteiras de responsabilidade para as partes interessadas (organização, gestores, colaboradores, etc.) [4] [5].

10.1. Responsabilidades

À organização, representada pela direção geral, cabe a responsabilidade de elaboração e atualização das políticas, garantindo que se mantêm eficientes, ajustadas à evolução do modelo de negócio, e alinhadas com os objetivos da empresa.

O CISO deverá garantir a implementação e operacionalidade das políticas aprovadas, e a realização de auditorias para avaliação da conformidade.

A todos os utilizadores cabe o dever de cumprir, e fazer cumprir, as políticas definidas e aprovadas pela organização; de fazer uso ético, moral, legal e seguro dos recursos que lhes são atribuídos ou de outra forma disponibilizados (quando para fins profissionais) pela organização.

A todos os utilizadores é vedada a remoção, alteração (seja física ou técnica), substituição ou desconexão sem o devido aviso prévio à equipa de TI, e a autorização para o efeito pela mesma equipa.

10.2. Utilização Aceitável

É considerada utilização aceitável a utilização dos recursos da organização que se verifiquem necessários ao desempenho das funções dos trabalhadores e ao negócio da mesma.

Os recursos disponibilizados pela organização não estão, regra geral, autorizados para tarefas não profissionais, sendo proibida a utilização para fins pessoais ou para fins que:

- Sejam abusivos, maliciosos, afetem negativamente o normal funcionamento dos sistemas, provoquem custos imprevistos não autorizados ou que estejam em violação da legislação portuguesa aplicável, da PUA ou demais regulamentos internos da organização;
- Sejam comerciais não afetos à organização, publicitários ou de proveito próprio do utilizador ou terceiros externos à organização;
- Representem ilícitos, fraudes, conteúdo pornográfico, obsceno, que tenham propósitos de difamar, assediar ou caluniar pessoas coletivas ou singulares;

Não é permitida a instalação de *software* sem a autorização prévia da equipa de TI nos dispositivos profissionais da organização.

A instalação de *software* pelos utilizadores é apenas permitida para *software* legal, licenciado e aprovado pela equipa de TI e quando feita para responder à necessidade de desempenho das funções profissionais. Os utilizadores deverão fazer por garantir que todos os direitos de propriedade intelectual são salvaguardados.

No sentido de dar cumprimento à PUA, os postos de trabalho poderão ser alvo de auditorias pelo CISO, pela equipa de TI, ou por outra entidade na qual o CISO delegue autoridade para o efeito.

10.2.1. BYOD

A FitTech reconhece as mais-valias na utilização de dispositivos pessoais para fins profissionais; prática designada BYOD (*Bring Your Own Device*). No entanto a mesma requer por parte dos utilizadores a compreensão e cumprimento das seguintes regras:

- a) A utilização de dispositivos pessoais para fins profissionais é permitida apenas após autorização do CISO, ou de equipa TI, através da plataforma ERP;
- b) É proibida a utilização de dispositivos com sistemas operativos ou outro software ilegal ou não licenciado, bem como ferramentas de *hacking* e/ou que permitam a violação de privacidade;
- c) A equipa de TI procederá à instalação de mecanismos de controlo, proteção e monitorização dos dispositivos (ex.: mecanismos de MDM) e manterá a capacidade de acesso remoto, remoção remota de informação ou inativação remota de dispositivos;

A utilização de dispositivos pessoais no âmbito da prática BYOD rege-se pelas mesmas regras que a de dispositivos corporativos como descrito abaixo (ver 10.3).

10.2.2. Acesso à Internet

A rede da organização permite o acesso à Internet, sendo concedido como ferramenta para o desempenho de funções profissionais e não pode ser usado para fins pessoais ou lúdicos, mesmo fora do horário de trabalho.

A organização admite um grau de tolerância na utilização do acesso à Internet para fins pessoais, principalmente quando ocorra fora do horário de trabalho e desde que não coloque em causa os serviços e recursos da organização.

A organização não impede, mas desencoraja, o acesso a caixas de correio pessoal através dos recursos fornecidos, especialmente em browser. Se o utilizador decidir, mesmo assim, o acesso a estes recursos deverá reconhecer e concordar com a monitorização automática do tráfego gerado, não sendo esta monitorização destinada a controlar os utilizadores. E reconhecer e concordar que a organização tem o direito de bloquear todo e qualquer endereço de Internet que considere desnecessário, abusivo ou prejudicial para a organização e para os seus recursos.

O facto de determinado endereço não estar bloqueado não deve ser visto como estando autorizado, ser seguro, ou de qualquer outra forma ser considerado validado pela organização.

Se o utilizador decidir usar os recursos da organização para fins privados, fora do horário da empresa, deverá evitar acesso a sites bancários ou outros onde seja necessário a introdução de credenciais do utilizador.

Nos postos de trabalho, os utilizadores deverão seguir uma política de *clear desk* e *clear screen*:

- Guardar, em local seguro quando fora de uso, todos os dispositivos de armazenamento de informação com informação classificada de “Confidencial”;
- Não ter acessíveis ou visíveis papeis, meios digitais, anotações, recados ou lembretes que contenham informação de negócio; evitar colar em paredes, divisórias, ecrãs ou secretárias qualquer dos elementos mencionados;
- Destruir documentos impressos, ou inutilizar meios de armazenamento de informação, usado os procedimentos definidos pela organização para o efeito;
- Não colocar recipientes com líquidos sobre as mesas ou secretárias onde também estejam dispositivos com informação digital armazenada;
- Computadores e impressoras terão política de ativação automática de *screensaver* após período de inatividade de 5 minutos; plataformas e sistema de informação da organização (ex.: ERP ou plataforma e-commerce) deverão bloquear a conta do utilizador após o mesmo período de inatividade;

10.2.3. Utilização de Correio Eletrónico

Os sistemas de e-mail são uma ferramenta ubíqua, atravessando as fronteiras da vida profissional e pessoal. Embora esta característica seja reconhecida pela FitTech, não dispensa a necessidade de estabelecer regras para a utilização deste meio de comunicação.

Estas regras são estabelecidas sem prejuízo do Artigo 22º do Código do Trabalho, onde consta que “o trabalhador goza do direito de reserva e confidencialidade relativamente ao conteúdo das mensagens de natureza pessoal e acesso a informação de carácter não profissional que envie, receba ou consulte, nomeadamente através do correio eletrónico”; no mesmo artigo é referido o poder “de o empregador estabelecer regras de utilização dos meios de comunicação na empresa, nomeadamente do correio eletrónico”.

O sistema de correio eletrónico é fornecido para que os utilizadores possam desempenhar as suas tarefas e está limitado às atividades de âmbito profissional

- a) Não é permitido o uso para fins pessoais do endereço de correio eletrónico fornecido pela organização;
- b) O endereço de correio eletrónico fornecido pela organização não pode ser registado em sites não profissionais (ex.: redes sociais, blogs, etc.) sem a autorização prévia da equipa de TI através da plataforma ERP da organização;
- c) Não é permitido o uso do email para envio de *chain mails* e *joke mails* ou outro tipo de envio massivo de mensagens;
- d) Se o utilizador verificar ser alvo de mensagens como as identificadas na alínea c) (anterior), deverá registar o caso através dos meios disponíveis (ver 10.7);
- e) A organização tem implementados mecanismos de controlo, monitorização e filtragem automática de mensagens que poderão interferir com o envio e

recepção das mesmas (ex.: eliminação automática de anexos identificados como perigosos ou maliciosos)

- f) Os controlos referidos no ponto anterior não significam um acesso ao conteúdo das mensagens por parte das equipas técnicas ou responsáveis da organização. A FitTech não acede a tais conteúdos sem que para isso tenha recebido um pedido judicial, ou se esse acesso tiver como único objetivo a prevenção ou deteção da prática de espionagem industrial, e desde que existam fundadas suspeitas; neste caso, o acesso será sempre realizado na presença do utilizador ao qual a caixa de correio foi atribuída, na presença do CISO e do DPO, sendo limitada, dentro das possibilidades do sistema, à visualização do assunto, da data e hora de envio ou recepção das mensagens;
- g) O envio de informação profissional está proibido em serviços de correio eletrónico acessíveis ao público (ex.: Sapo, Gmail, Hotmail); excecionalmente, após aprovação do CISO, ou de quem este delegar competência, o uso destes serviços poderá ser usado;
- h) O serviço de correio eletrónico da organização não pode ser usado para envio de mensagens de marketing ou para listas de distribuição massiva;
- i) Não é permitida a delegação de caixas de correio, em ausências não previstas e/ou em períodos de férias, sem a autorização dos utilizadores aos quais as caixas de correio foram atribuídas;
- j) Em caso de término de contrato, na saída do trabalhador, o endereço de correio eletrónico deverá reencaminhar para o trabalhador em substituição, ou não existindo, para o superior hierárquico direto. Este reencaminhamento será mantido durante o período definido pela organização;
- k) Após saída do trabalhador, ao acesso endereços de correio nominais, só será feito após autorização do mesmo e tendo com objetivo a busca de informação que se suspeite não existir noutras caixas de correio.

A título excecional, caso surja a necessidade de envio de algum e-mail não profissional através da conta de correio da organização, com origem numa emergência real e em que não exista possibilidade de uso de outro meio de comunicação, a organização autoriza a utilização para o fim pessoal desde que:

- Os e-mails sejam removidos no menor tempo possível;
- A utilização excecional não coloque em causa o normal funcionamento do sistema de correio eletrónico da organização;
- Não sejam transmitidas mensagens ofensivas ou com conteúdo moralmente condenável (ex.: pornográfica, ofensas à raça, cor, orientação política ou sexual, etc.)
- O utilizar reconhece, e aceita, que a organização tem implementados mecanismos de monitorização que poderão filtrar ou de outra forma interferir com o envio de mensagens (ex.: remoção de mensagens de dimensão superior

ao permitido) e que estes mecanismos não permitem distinguir mensagens pessoais ao abrigo da regra de exceção.

10.3. Dispositivos Móveis

Dispositivos móveis são todos os ativos onde possa ser armazenada informação corporativa que se encontre no âmbito desta política, isto é, dispositivos da organização e pessoais (BYOD) que tenham capacidade para armazenar informação e que possam ser transportados, ex., *smartphones*, portáteis, etc.

A utilização de dispositivos móveis requer a autorização prévia do CISO, refletida em registo informático no sistema ERP da organização.

O uso de dispositivos móveis para fins profissionais implica a aceitação desta política, e a aceitação da instalação dos mecanismos de controlo definidos pela organização, incluindo controlos que possibilitem, direta ou indiretamente, a monitorização da informação presente no dispositivo.

Aos dispositivos móveis, e aos seus utilizadores, é imposto:

- A proibição da utilização de redes Wi-Fi abertas ou públicas;
- A obrigatoriedade de manter os dispositivos devidamente atualizados, livre de *software* que não tenha sido previamente aprovado pela organização, e com os mecanismos de controlo instalados pela organização intactos;
- A obrigatoriedade de usar, quando suportado pelos dispositivos, as capacidades de cifra de dados, antivírus e *firewall*;
- A proibição de instalar *software* não autorizado, ilegal, não licenciado, de carácter lúcido, ou que coloque em causa os direitos de autor, a integridade da rede e serviços da organização ou integridade da segurança da informação;
- A utilização, quando suportado pelos dispositivos e aplicável, de processo de *lockout*, eliminação remota de informação ou desativação remota;
- A proibição de procedimentos de *jailbreak*, *root*, ou outro procedimento que tenha como finalidade contornar as proteções e mecanismos de segurança do fabricante;

Quando usados para acesso a e-mail ou informação Confidencial, o uso de dispositivos móveis obriga à aceitação de controlo parcial do dispositivo pela organização através de mecanismos MDM.

A salvaguarda da informação corporativa presente nos dispositivos móveis é da responsabilidade dos respetivos utilizadores, devendo os mesmos zelar pela segurança física dos dispositivos e, na eventualidade de extravio (roubo, perde, etc.) reportar o evento ao CISO o mais brevemente possível.

10.4. Trabalho Remoto

Compreende a realização de todo e qualquer trabalho fora dos ambientes identificados como escritórios da empresa, incluindo locais não tradicionais, como sejam a realização de trabalho através de dispositivos móveis, utilização de ambientes virtuais de trabalho, trabalho em local flexível, teletrabalho ou trabalho remoto.

A FitTech permite aos seus colaboradores a realização de trabalho remoto, com autorização prévia pelo CISO ou de forma automática em função da necessidade, através da disponibilização de recursos adequados e devidamente enquadrados na PUA. Excecionalmente, será admitida a utilização de dispositivos pessoais, em regime BYOD, através da autorização do CISO, da configuração e aceitação dos controlos de segurança (*firewall*, antivírus, etc.) previstos na PUA. Esta autorização é representada pelo registo informático no sistema ERP da organização.

Aos dispositivos colocados à disposição dos trabalhadores, para efeitos de realização de trabalho remoto, está vedado o acesso por utilizadores sem vínculo contratual com a **FiTech Solutions**, bem como a instalação de *software* que não cumpra com a PUA, que seja ilegal, que ameace a segurança da informação detida pela organização e que se encontre no âmbito da PUA.

Dispositivos usados sob o regime BYOD não podem tratar informação com classificação Confidencial.

As sessões de trabalho remoto devem ocorrer sempre através dos canais seguros colocados à disposição dos utilizadores, nomeadamente VPN corporativa, autenticação por dois fatores (2FA) e, quando disponíveis em plataformas WEB, por https. Estas sessões seguem as mesmas regras, e estão abrangidas pelos mesmos direitos e obrigações no âmbito da PUA, que o trabalho realizado nos escritórios da FitTech (ex.: continuidade de negócio, salvaguarda de informação, etc.).

10.5. Cifra de Informação

A FitTech aplica mecanismos de cifra para transmissão de informação entre as suas plataformas, nos dispositivos corporativos e BYOD, e na comunicação com os seus clientes e fornecedores.

Sempre que possível, os utilizadores deverão considerar:

- Que a utilização de cifra tem como objetivo:
 - Garantir a segurança em transmissão eletrónica de informação através da cifra de informação ou do uso de assinaturas digitais para validação de identidade dos intervenientes e integridade da informação
 - Possibilitar a utilização de autenticações fortes como 2FA;

- Possibilitar a assinatura eletrónica em documentos digitais de modo a garantir autoria, integridade e não repúdio;
- Os dispositivos móveis devem fazer uso de mecanismos de cifra (ex.: portáteis com discos cifrados) e não devem conter informação de classificação “Confidencial” se não suportarem cifra de dados;
- Só é permitida cifra com algoritmos previamente aprovados pela equipa de TI, nomeadamente:
 - Cifra simétrica por triple DES, RC5, Rijndel (AES), IDEA, Twofish;
 - Cifra assimétrica por RSA (RSAES-OAEP, RSASS-PSS), baseados em *elliptic curve* (ECDH, ECIES/ ECDSA).
 - Em funções *hash* para palavras-chave preferir bcrypt (na versão \$2a\$ ou superior)
- Recorrer a chaves simétricas com, no mínimo, 128 bits, e chaves assimétricas com, no mínimo, 2048 bits.
- Utilizar sistemas automatizados para gestão de chaves e garantir que, na transmissão de chaves a cifra usada para proteger as chaves tem grau de complexidade superior às chaves transmitidas;
- Na cifra com recurso a par de chaves assimétricas, a validade das chaves não deverá ser superior a um ano.

10.6. Gestão de Redes e Serviços

A administração dos sistemas da organização deverá ser feita, apenas, por trabalhadores qualificados, devidamente credenciados e autorizados, com o conhecimento e formação adequados para um desempenho eficaz das funções atribuídas.

Todos os recursos de TI da organização devem ser obtidos por canais previamente validados e aprovados, devendo ser criados critérios para a aquisição de novos sistemas, para a atualização de *software* e para a elaboração de um plano de testes a novas versões de *software*. Estes critérios devem promover:

- A manutenção das atualizações de sistemas operativos, *software* e *firmware* dos recursos da organização;
- O controlo de *software* disponibilizado internamente, proibindo a utilização de versões de desenvolvimento em ambientes produtivos;
- A verificação da integridade dos dados e dos executáveis colocados em ambiente produtivo;
- A prevenção contra *software* malicioso e infeções por vírus informáticos;
- A criação de uma lista de *software* aprovado para uso na organização;

É mantido um inventário de ativos informáticos, com identificação de todos os ativos em uso na organização, dos seus responsáveis diretos (ex.: para plataformas externas qual o utilizador que tem acesso de administração) e do nível de criticidade ou risco para o

negócio da organização. O acesso aos vários ativos deverá ser aprovado pelo responsável direto do ativo.

Sempre que um ativo se torne obsoleto, e deixe de ser usado, deverá ser desativado e retirado da rede, e o inventário de ativos atualizado em conformidade.

Na gestão de recursos de rede, deverá ser utilizado o princípio de menor acesso possível para a execução da tarefa e não devem ser usadas relações de confiança na atribuição de permissões ou na elaboração de perfis de acesso.

Não é permitido o uso de contas com acesso privilegiado (ex.: administrador de domínio, ou *root*) quando a tarefa a executar é possível de ser feita com contas com menos privilégios.

Deverão ser implementados controlos que permitam a deteção, recuperação e prevenção de ataques por software malicioso. Estes controlos deverão estar permanentemente ativos nos recursos da organização e serem atualizados automaticamente.

Nos recursos críticos deverão ser, adicionalmente, implementados controlos de monitorização e deteção de vulnerabilidades, devendo estas ser analisadas e resolvidas de acordo com o plano de resolução que terá como base a criticidade da vulnerabilidade.

A criação de cópias de informação, *backups*, ou salvaguarda da informação, é necessária para a continuidade do negócio da organização, devendo ser realizadas na extensão e frequência tais que reflitam os requisitos e as estratégias definidas pela gestão para o negócio.

A equipa de TI deverá monitorizar a realização das cópias de modo a garantir a sua correta execução e de possibilitar a correção de falhas no processo. As cópias deverão ser testadas regularmente.

Cabe à equipa de TI elaborar, e manter atualizadas, as instruções necessárias à realização de cópias e à sua recuperação na eventualidade de desastre.

10.6.1. Gestão de Contas e Acessos

O acesso dos utilizadores aos recursos da organização deverá ser alvo de processo de aprovação e registo de forma que:

- A criação de contas e perfis e utilizadores permita a identificação inequívoca da pessoa associada;
- É da responsabilidade dos responsáveis pelos ativos a requisição da criação de perfis ou contas e a devida autorização do acesso dos utilizadores;
- Seja possível a revisão, regular, das contas e perfis criados, bem como dos acessos associados, de forma a reduzir ou evitar a estagnação das informações

de acesso face a alterações às responsabilidades, transferências, cessação de funções, etc.;

- O controlo de acessos aos recursos da organização deverá ser feito através de nomes de utilizador e palavra-chave associada, que terão de ser únicos por utilizador e permitir a responsabilização do mesmo pelas suas ações;
- Exista uma associação entre as contas ou perfis dos utilizadores e as funções que os mesmos desempenham de modo que o utilizador não tenha mais acessos do que os que realmente necessita e para os quais está autorizado.

Sempre que os utilizadores necessitem de acesso remoto aos recursos da organização disponíveis *on-premise*, deverão ter o pedido e a respetiva autorização no sistema ERP da organização.

Este acesso deverá ser realizado exclusivamente pelos canais disponibilizados pela organização, especificamente através de VPN, estando os utilizadores proibidos de fazer uso de soluções de acesso remoto de terceiros.

Deverão ser implementados mecanismos de monitorização e registo de *logs* para acesso dos utilizadores aos recursos da organização.

10.6.2. Gestão de Palavras-Chave

As palavras-chave de acessos aos recursos da organização são da responsabilidade dos utilizadores respetivos. A escolha de palavras-chave é do critério, estando os utilizadores sujeitos aos seguintes padrões¹:

- Não devem conter, em parte ou no todo, o nome de utilizador atribuído ou o nome do utilizador;
- Deverá ser dada prioridade à dimensão, não podendo ter menos de 16 caracteres. A complexidade baseada em padrões não aumenta a segurança das palavras-chave na mesma proporção em que a quantidade de caracteres o faz;
- Para recursos críticos, deverão ser renovadas anualmente (a cada 365 dias);
- Deverão ser diferentes das últimas três.

Os requisitos para palavras-chave em dispositivos BYOD são os mesmos, podendo o acesso ao dispositivo ser realizado por controlo biométrico em alternativa ao uso de palavra-chave.

¹ Baseados nas recomendações da NIST 800-63, revisão para 2024

Os utilizadores devem reconhecer que as palavras-chave são confidenciais, pessoais e intransmissíveis. Devem por isso ser registadas em *software* de gestão de palavras-chave para que não seja necessário memorizar as mesmas, não devem ser escritas (em papel, em e-mails ou outras formas de comunicação) ou partilhadas com qualquer outro utilizador (mesmo que dos departamentos técnicos como o de TI).

Em sistemas com opção para memorizar as palavras-chave, a opção não poderá ser usada, devendo ser desativada se assim for possível.

Caso o utilizador suspeite que a sua palavra-chave foi comprometida, deverá reportar a suspeita à equipa de TI de acordo com os procedimentos definidos (ver 10.7)

Quaisquer palavras-chave fornecidas pela equipa de TI devem ser consideradas como palavras-chave de acesso inicial e alteradas no primeiro acesso que o utilizador efetuar ao respetivo recurso.

10.6.3. Desenvolvimento de Aplicações

A FitTech tem parte do seu negócio suportada pelo desenvolvimento de soluções de *software* próprias. De modo a garantir a segurança da sua Propriedade Intelectual, as seguintes regras são aplicáveis ao desenvolvimento interno:

- Implementar controlos de acesso ao código fonte de software e *firmware* detido pela organização, das suas especificações e documentação técnica;
- Implementar controlos que permitam garantir a integridade do código fonte e detetar e evitar modificações não autorizadas;
- Restringir apenas aos trabalhadores que atuam no desenvolvimento das soluções, o acesso ao código fonte das mesmas, segregando o acesso de modo que apenas tenham acesso os trabalhadores que diretamente desenvolvem cada uma das soluções;
- Rever regularmente os acessos e evitar utilizadores com acesso a código fonte de soluções em que já não se encontram afetos;
- Implementar repositórios de gestão e salvaguarda de código fonte (SCM);
- Implementar controlos que permitam o registo de *logs* de acesso aos repositórios de código fonte e ao código neles guardado.

Deverá existir segregação entre ambientes de desenvolvimento e ambientes produtivos com perfis de acesso diferentes e de forma que não existam ferramentas de desenvolvimento instaladas em ambientes produtivos-

Só deverá ser possível transferir *software* do ambiente de desenvolvimento para o ambiente produtivo com validação da equipa de TI e aprovação do CISO, de acordo com as práticas a definir pelas equipas de TI e de desenvolvimento.

10.7. Registo de Eventos ou Incidentes

O **Registo de Eventos ou Incidentes** é constituído pelas regras necessárias para produção, manutenção, monitorização e revisão de registos de eventos com informação sobre atividade de utilizadores, falhas ou eventos de segurança, ou exceções ao normal funcionamento dos serviços da organização.

O acesso aos sistemas de registo de eventos deverá ser controlado através de medidas de controlo de acesso para que apenas utilizadores com perfis autorizados possam aceder à informação, fazendo-o de forma a permitir a rastreabilidade dos utilizadores e identificação de quem, quando e a que informação acedeu.

A organização identifica as situações anómalas, que possibilitam a criação de alarmes para a evidência de utilização indevida dos seus sistemas. Estas situações são monitorizadas e registadas em sistema dedicado, que deverá incluir, sempre que possível:

- Identificação dos utilizadores e das atividades por eles realizadas, contendo as datas de acessos, duração dos mesmos e detalhes chave para a classificação dos eventos (ex. momento de acesso, *login* e *logout*), bem como dos recursos acedidos ou usados;
- Registo das tentativas de acesso, falhas e bem-sucedidas;
- Registo de alterações de configurações, ou tentativas de alterações das configurações de recursos da organização;
- Registo do uso de privilégios não previstos pelos perfis atribuídos aos utilizadores;
- Registo das aplicações usadas pelos utilizadores, dos acessos a ficheiros e tipos dos mesmos;
- Registo dos recursos de rede acedidos;
- A cifra dos dados recolhidos para segurança de informação pessoal que possa ser registada;

Quando os eventos surgem por iniciativa dos utilizadores, os mesmos devem direcionar o registo da situação para a equipa de TI, através das ferramentas disponíveis na plataforma ERP da organização, do endereço de e-mail **security@fittech.pt**, ou pessoalmente, considerando:

- Os eventos ou incidentes devem ser reportados no menor espaço de tempo possível;
- O utilizador deverá fornecer toda a informação que considere relevante, indicado data e hora em que tomou conhecimento do evento, contexto (ex.: que ações estava a tomar, que aplicações usava, etc.), localização e recursos usados;

- Cabe à equipa de TI, e ao CISO, a devida classificação dos registos, tomada de decisão nas ações a aplicar e, caso aplicável, da transmissão do evento a entidades interessadas (ex.: CNPD, CNCS, etc.);
- Caso a evento envolva dispositivos móveis, e existindo a capacidade no dispositivo, será executada ação de eliminação de informação, ou invalidação, remota;

A organização implementa procedimentos para análise destes registos de eventos e a realização periódica de relatórios e auditorias para efeitos de verificação interna, formação e melhoria contínua dos sistemas, desta política e das práticas dela derivadas.

Os registos de eventos, e a informação associada, são mantidos durante o tempo máximo legalmente permitido, de acordo com a legislação aplicável e o âmbito da informação (ex.: tempo mínimo para retenção de *logs*).

Cabe à organização garantir a proteção contra destruição, manipulação e acesso não autorizados aos registos.

Referências Bibliográficas

- [1] Joana Lobo - IT Security Unit Leader, APCER, “apcergroup.com,” APCER, 03 10 2024. [Online]. Available: <https://apcergroup.com/pt/noticias-e-destaques/4354/ciberseguranca-aumentar-a-confianca-digital-das-empresas-portuguesas>. [Acedido em 19 12 2024].

- [2] Agência para a Modernização Administrativa, “Portal de serviços públicos da República Portuguesa,” AMA, 30 09 2024. [Online]. Available: <https://www2.gov.pt/inicio/espaco-empresa/escolher-a-forma-legal-da-sua-empresa>. [Acedido em 12 2024].

- [3] . A. Miguel, A. G. Marques e J. M. Annes, Risco Empresarial e Cibersegurança, 1ª ed., FCA, 2021.

- [4] ISO/IEC, ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements, ISO/IEC, 2022.

- [5] ISO/IEC, ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls, ISO/IEC, 2022.

Glossário

Termo ou acrónimo	Descrição
Dados Pessoais	Qualquer informação de qualquer natureza, incluindo som e imagem, relativa a uma pessoa singular que pode ser identificável ou identificada direta ou indiretamente (titular dos dados), designadamente por referência a um identificador como o nome, número de identificação, ou a um ou mais elementos específicos da sua identidade física, fisiológica, mental, económica, cultural ou social.
Local de trabalho	Todo e qualquer local em que o utilizador se encontra em virtude do seu trabalho, incluindo situações de trabalho remoto.
Recurso	Ativo ou grupo de ativos móveis ou imóveis e qualquer serviço, próprio, alugado ou subcontratado.
Utilizador	Colaborador ou subcontratado que utilize um recurso da organização.
Cifra ou Encriptação	Processo de codificação da informação que impossibilita a sua leitura sem a chave de decodificação apropriada.
Cifra criptográfica	Algoritmo usado na encriptação e desencriptação da informação através da sua transformação, por meio da mudança de ordem, aparência, substituição ou de outra estratégia que a torna ilegível.
Chave criptográfica	Fragmento de informação que determina o resultado da transformação produzida por uma cifra e que é necessária para a sua desencriptação e leitura.

Chave Simétrica	Chave criptográfica partilhada entre o emissor e o recetor, que permite a respetiva encriptação e desencriptação da informação.
Chave Assimétrica	Também conhecida como Chave Pública, são utilizadas por cifras criptográficas que recorrem a duas chaves criptográficas, uma pública e outra privada, para encriptar e desencriptar informação.
Evento	Ocorrência ou alteração de um conjunto particular de circunstâncias. Qualquer alteração, erro ou interrupção em uma infraestrutura de TI, como por exemplo, uma falha no sistema, ou um utilizador que esqueceu a palavra-chave.
HTTPs	Comunicação segura na utilização de Internet; protocolo HTTP sobre <i>Transport Layer Security</i> (TLS).
Incidente	Um evento com um efeito adverso real na segurança das redes e dos sistemas de informação
Risco	Combinação da probabilidade de um acontecimento e das suas consequências (impacto).
Gestão do risco	É o processo através do qual a FitTech analisa, metodicamente, os riscos inerentes às atividades que desenvolve, com o objetivo de atingir uma vantagem sustentada em cada atividade individual e no conjunto de todas as atividades.
Salvaguarda	Ato, ou medida de proteção, defesa, garantia, que visa ressaltar ou acautelar a disponibilidade da informação.
Screensaver	Programa de computador que preenche o ecrã com imagens, texto, padrões ou cor, após um período de inatividade do utilizador.

Auditoria	Processo sistemático, independente e documentado para obter evidências de Auditoria e respetiva avaliação objetiva, com vista a determinar em que medida os critérios de auditoria são satisfeitos
Requisito	Necessidade ou expectativa expressa, implícita ou obrigatória
On-Premise	<i>Software</i> instalado e executado em computadores (ou servidores) que se encontram nas instalações físicas da organização.